



ГАОУ ВПО «Дагестанский государственный университет народного хозяйства»

Кафедра «Прикладная математика и информационных технологий»

**Учебное пособие
по дисциплине**

«Информационная безопасность»

Для специальности среднего профессионального образования

09.02.05 «Прикладная информатика (по отраслям)»

Разработчик: Алимагомедов Магомед Габидуллаевич, старший преподаватель кафедры «Прикладная математика и информационные технологии» ДГУНХ



Махачкала – 2017

УДК 004.056.5

ББК 32.973.2

Составитель: Алимагомедов Магомед Габидуллаевич старший преподаватель кафедры Прикладной математики и информационных технологий ДГУНХ.

Внутренний рецензент: Якубов Амучи Загирович, кандидат физико-математических наук, доцент кафедры информатики ДГУНХ

Внешний рецензент: Меджидов Зияудин Гаджиевич, кандидат физико-математических наук, старший научный сотрудник Отдела математики и информатики Дагестанского научного центра Российской Академии Наук

Учебное пособие дисциплины Информационная безопасность размещена на сайте www.dginh.ru.

Алимагомедов М.Г. Учебное пособие по дисциплине «Информационная безопасность» для специальности 09.02.05 «Прикладная информатика (по отраслям)». Махачкала: ДГУНХ, 2017.

Печатается по решению Учебно-методического совета Дагестанского государственного университета народного хозяйства.

Содержание теоретического материала (лекций) по дисциплине

№ п/ п	Тема и развернутый план лекций	Ко- личе- ство часов
1.	Тема 1. Введение в информационную безопасность. 1. <i>Основные понятия и определения.</i> Определение информационной безопасности, угроз, уязвимости. Цели защиты. 2. <i>Характеристики информации, применительно к задачам защиты.</i> Физические и экономические характеристики. Взаимосвязь между стоимостями. 3. <i>Информационная безопасность в условиях функционирования в России глобальных сетей.</i> Тенденции развития преступлений в сфере информационных технологий. Internet как среда для компьютерных преступлений.	2
2.	Тема 2. Задачи и методы информационной безопасности. 1. <i>Основные задачи информационной безопасности.</i> Перечисление и пояснение основных задач информационной безопасности. 2. <i>Основные методы обеспечения защиты информационной системы.</i> Законодательные, административные, технические. Классификация методов.	2
3.	Тема 3. Угрозы информационной безопасности. 1. <i>Ключевые свойства информации. Понятие угрозы.</i> Секретность, конфиденциальность, доступность. Определение и классификация угроз. 2. <i>Угроза нарушения конфиденциальности.</i> Служебная и предметная информация. Непрерывность защиты. 3. <i>Угроза нарушения целостности.</i> Статическая и динамическая целостность. Примеры нарушений целостности. 4. <i>Угроза отказа служб.</i> Классификация угроз и методы минимизации последствий.	2
4.	Тема 4. Потенциальные противники и атаки. 1. <i>Виды противников или "нарушителей".</i> Классификация нарушителей: пользователи, хакеры, специальные агентства. Определение и характеристики хакеров. 2. <i>Виды и каналы утечки информации.</i> Непосредственные и косвенные каналы. Каналы, предполагающие изменение структуры информационной структуры. 3. <i>Классификация атак.</i> Классификации по месту возникновения, способу воздействия на информационную структуру, по направленности на компонент информационной системы. Характеристика атак систем управления базами данных и операционных систем. 4. <i>Сетевые атаки.</i> Пассивная, отказ в обслуживании, модификация потока данных, создание ложного потока данных, повторное использование.	2

5.	Тема 5. Основные положения теории информационной безопасности информационных систем. <i>Подходы к обеспечению информационной безопасности.</i> Формулирование основных положений информационных положений. <i>Принципы обеспечения информационной безопасности.</i> Системность, комплексность, непрерывность, разумная достаточность, гибкость, открытость алгоритмов, простота применения. <i>Формальные модели доступа к данным.</i> Классификация моделей. Дискреционная модель. Мандатная модель. <i>Монитор безопасности и его функции.</i> Определение монитора безопасности. Характеристика основных функций.	2
6.	Тема 6. Политика безопасности информационных систем. <i>Административный уровень защиты информации.</i> Разделение политики безопасности по уровням. Описание функций административного уровня безопасности. <i>Разработка и реализация политики безопасности.</i> Итерационная процедура выработки политики безопасности. Функции политики безопасности по уровням. Вопросы, решаемые при разработке политики безопасности. <i>Таксономия нарушений информационной безопасности вычислительной системы и причины, обуславливающие их существование.</i> Анализ надежности и защищенности операционных систем разных семейств. Выявление недостатков этих операционных систем, приводящих к снижению уровня безопасности. <i>Анализ способов нарушений безопасности.</i> Анализ и процентное соотношение успешности различных типов атак в разных операционных системах. Основные выводы о защищенности современных операционных систем.	2
7.	Тема 7. Организационно-правовые методы информационной безопасности. <i>Основные нормативные руководящие документы, касающиеся государственной тайны, нормативно-справочные документы.</i> Уровни правового обеспечения информационной безопасности. Перечисление документов и статей в них, касающихся вопросов информационной безопасности. <i>Место информационной безопасности экономических систем в национальной безопасности страны.</i> Национальная безопасность России, информационная безопасность в рамках национальной безопасности. Основные принципы обеспечения безопасности. <i>Концепция информационной безопасности.</i> Доктрина информационной безопасности России. Четыре основные составляющие национальных интересов Российской Федерации в информационной сфере. <i>Назначение и задачи в сфере обеспечения информационной безопасности на уровне государства.</i> Анализ недостатков ин-	2

	формационной безопасности Российской Федерации. Основные задачи обеспечения информационной безопасности. Правовые методы обеспечения информационной безопасности.	
8.	Тема 8. Основные понятия криптографии. 1. История развития криптографии 2. <i>Определение базовых понятий.</i> Понятие криптографии. 3. <i>Задачи и методы криптографии.</i> Секретность, аутентификация, целостность, неоспоримость.	2
9	Тема 9. Алгоритмы шифрования. 1. Общая характеристика шифров. 2. Алгоритм обмена ключами. 3. Симметричные алгоритмы. 4. Асимметричные алгоритмы.	4
10	Тема 10. Криптографические протоколы. 1. <i>Понятие протокола.</i> Определение протокола, условия протоколов. Виды протоколов. 2. <i>Основные криптографические протоколы.</i> Схема обмена ключами, аутентификация, распределение ответственности, цифровая подпись. Вспомогательные криптографические протоколы. 3. <i>Электронная цифровая подпись.</i> Задачи, решаемые цифровой подписью. Схема создания и проверки электронной цифровой подписи. 4. <i>Модели основных криптоаналитических атак.</i> Атака методом сведения к середине. Словарная атака. Четыре основных подхода к анализу криптографических протоколов.	2
11	Тема 11. Программно-технические методы защиты. 1. <i>Программно-аппаратные средства.</i> Основные аппаратные средства защиты. Основные программные средства защиты. Преимущества и недостатки программных средств защиты. 2. <i>Понятие информационного сервиса безопасности. Виды сервисов безопасности.</i> Основные виды сервисов. Классификация видов сервисов. 3. <i>Идентификация и аутентификация. Основные методы идентификации и аутентификации.</i> Преимущества и недостатки парольной идентификации. Дополнительные меры защиты. 4. <i>Биометрические показатели пользователей и возможности их применения.</i> Основные методики идентификации по биометрическим показателям. Недостатки идентификации по биометрическим показателям. 5. <i>Сервисы управления доступом.</i> Матрица списков доступа. Анализ дискреционного и мандатного доступа. 6. <i>Протоколирование и аудит.</i> Задачи аудита. События, рекомендуемые для протоколирования. 7. <i>Журнал аудита. Активный аудит.</i> Модели активного аудита. Двухуровневая модель аудита.	4

	8. <i>Основы защиты корпоративных экономических информационных систем.</i> Основные аспекты информационной безопасности корпоративных экономических информационных систем. Потенциальные угрозы корпоративным ЭИС. 9. <i>Основы защиты Internet-подключений.</i> Основные положения обмена информацией в открытых сетях. Понятие межсетевого экрана. Программные средства защиты Internet-подключений.	
12	Тема 12. Защита данных и сервисов от воздействия вредоносных программ. 1. <i>Вирусы. Виды вирусов.</i> Определение вируса и программной закладки. Классификации вирусов. 2. <i>Антивирусное программное обеспечение.</i> Методики обнаружения вирусов и виды антивирусного программного обеспечения. Недостатки антивирусов. 3. <i>Защита системы электронной почты. Спам.</i> Определение спама, статистика угроз. Угрозы, связанные со спамом. Методики работы спам-фильтров.	2
13	Тема 13. Стандарты обеспечения информационной безопасности. 1. <i>Критерии безопасности компьютерных систем министерства обороны США ("Оранжевая книга").</i> Понятие оценочного стандарта. Основные положения "Оранжевой книги". Критерии степени доверия и требования безопасности. 2. <i>Руководящие документы Гостехкомиссии России.</i> Классы защищенности, группы и классы пользователей, их права и возможности. 3. <i>Международные стандарты информационной безопасности.</i> Стандарт ISO/IEC 15408 "Общие критерии". Описание требований безопасности и характеристик угроз. Классы функциональных требований. Классификационная статистика.	2
14	Тема 14. Основные технологии построения защищённых экономических информационных систем. 1. <i>Общие принципы построения защищенных систем.</i> Выдержки из открытой концепции "Защищенные информационные системы. Информационный документ корпорации Microsoft." Цели защищенных информационных систем: безопасность, безотказность, деловая добросовестность. 2. <i>Средства разработки и правила их реализации.</i> Основные средства, методика их реализации, практические аспекты функционирования. 3. <i>Фундаментальные проблемы, возникающие при построении защищенных информационных систем.</i> Политические вопросы, технические и социальные аспекты.	2
	Итого:	32

Аннотация

Дисциплина "Информационная безопасность" входит в учебный план подготовки специалистов по направлению 09.02.05 «Прикладная информатика (по отраслям)». Вопросы безопасности на современном уровне развития информационных технологий становятся наиболее актуальными, особенно в экономической сфере, так как именно экономические информационные системы подвергаются наибольшему количеству атак со стороны злоумышленников. Поэтому специалист в области экономических информационных систем должен знать теоретические подходы к обеспечению информационной безопасности, уметь применять на практике методы защиты информации и методики проектирования защищенных информационных систем. Изучение основ информационной безопасности является одним из факторов полноценной подготовки специалиста информатика-экономиста.

"Информационная безопасность" является логическим продолжением таких дисциплин, как "Операционные системы, среды и оболочки", "Базы данных", "Вычислительные машины, сети и системы телекоммуникации", углубляет и расширяет знания студентов в специфических вопросах защиты информации на всех уровнях функционирования экономических информационных систем.

Учебное пособие предназначено для студентов 4 курса (на базе 9 классов) Бизнес-колледжа специальности "Прикладная информатика (по отраслям)".

Учебное пособие составлено согласно требованиям Федерального государственного образовательного стандарта по специальности 09.02.05 «Прикладная информатика (по отраслям)». Учебное пособие включает 96 часов аудиторных занятий, в том числе 32 часов лекционных занятий и 64 часов семинарских занятий, а также 76 часов самостоятельной работы. Завершается дисциплина экзаменом. По дисциплине предусмотрена тематика рефератов.

Учебное пособие разработано доцентом кафедры Прикладная математика и Информационные технологии факультета ДГУНХ Алимагомедовым М.Г.

Тема 1. Введение в информационную безопасность.

п.1. Основные понятия и определения.

Наше время – время глобальной информатизации общества.

В двадцать первом веке движущей силой и главным объектом всех отраслей человеческой деятельности становится информация, состояние каналов, сетей и безопасность серверов, которые будут основой экономического развития.

Справедлив афоризм: «Кто владеет информацией, тот владеет миром». («Он слишком много знал»).

По мере развития и усложнения средств, методов и форм автоматизации процессов обработки информации повышается зависимость общества от степени безопасности используемых им информационных технологий, от которых порой зависит благополучие и даже жизнь многих людей.

Некоторые современные формы бизнеса полностью базируются на сетевых технологиях (электронная торговля, IP-телефония, сетевое провайдерство и т.д.) и по этой причине особенно уязвимы.

Быстрое развитие информационных технологий не только предоставляет новые возможности по защите информации, но и объективно затрудняет обеспечение надежной защиты, если опираться только на программно-технические меры. Причин здесь несколько:

- повышение быстродействия микросхем, развитие архитектур с высокой степенью параллелизма позволяет методом грубой силы преодолевать барьеры (прежде всего криптографические), ранее казавшиеся неприступными;
- развитие сетей и сетевых технологий, увеличение числа связей между информационными системами, рост пропускной способности каналов расширяют круг злоумышленников, имеющих техническую возможность организовывать атаки;
- появление новых информационных сервисов ведет и к образованию новых уязвимых мест как «внутри» сервисов, так и на их стыках;
- конкуренция среди производителей ПО заставляет сокращать сроки разработки, что приводит к снижению качества тестирования и выпуску продуктов с дефектами защиты;
- навязываемая потребителям парадигма постоянного наращивания мощности аппаратного и программного обеспечения не позволяет долго оставаться в рамках надежных, апробированных конфигураций и, кроме того, вступает в конфликт с бюджетными ограничениями, из-за чего снижается доля ассигнований на безопасность.

Безопасность представляет собой комплексное понятие, куда входят технические аспекты надежности оборудования, качество питающей сети, уязвимость программного обеспечения и т.д. Вы можете отключить сеть от Интернет, установить систему для обеспечения дисковой защиты и т.д., но в случае, например, пожара можете потерять базу данных, которую создавали несколько лет. Вам ведь все равно, нанесен ли ущерб хакером или несчастным случаем! Проектируя сеть, надо с самого начала учитывать все возможные угрозы, как объективные, так и субъективные.

За последние десятилетия толкование термина информационная безопас-

ность претерпело значительные изменения. Более того, словосочетание информационная безопасность в разных контекстах может иметь различный смысл.

Например, в Доктрине информационной безопасности страны или других законодательных актах термин «информационная безопасность» обычно используется в широком смысле. Информационная безопасность определяется как состояние защищенности информационной среды общества, обеспечивающее ее формирование, использование и развитие в интересах личности, общества и государства.

Под **информационной безопасностью** мы будем понимать защищенность информации и поддерживающей инфраструктуры от случайных или преднамеренных воздействий естественного или искусственного характера, которые могут нанести неприемлемый ущерб субъектам информационных отношений, в том числе владельцам и пользователям информации и поддерживающей инфраструктуры.

Когда говорят о защите информации, само понятие "информация" берут максимально широким. Под информацией понимают сведения о лицах, предметах, фактах, событиях, явлениях и процессах независимо от формы их представления.

Если говорят о защите информации в вычислительных системах, то используют следующее определение: "Информация – это любые данные, находящиеся в памяти вычислительной системы, любое сообщение, пересылаемое по сети, любой файл, хранящийся на каком-либо носителе".

Под информационной системой понимают упорядоченную совокупность документов (массивов документов) и информационных технологий, реализующих информационные процессы (сбор, обработку, накопление, хранение, поиска и распространения информации). Информационными ресурсами называют документы (массивы документов), существующие отдельно или в составе информационных систем.

Информацию по степени доступа разделяют на открытую и ограниченного доступа. К информации ограниченного доступа относятся государственная тайна и конфиденциальная информация (служебная тайна, коммерческая тайна и персональные данные, позволяющие идентифицировать личность гражданина).

Информация является объектом гражданских прав. Собственник информационных ресурсов, систем и технологий – это субъект с полномочиями владения, пользования и распоряжения указанными объектами. Владелец информационных ресурсов, систем и технологий является субъект с полномочиями владения и пользования указанными объектами. Под пользователем информации будем понимать субъекта, обращающегося к информационной системе за получением необходимой ему информации и пользующегося ею.

В вопросах защиты информации применяются два термина: "информационная безопасность" и "защита информации". Оба эти термина являются переводом на русский язык английского термина "information security". Но обычно под информационной безопасностью понимаются теоретические вопросы и разработки, а под защитой информации – описание практических мероприятий, руководства для конечных пользователей, готовые алгоритмы.

Защитой информации называют деятельность по предотвращению утечки защищаемой информации, несанкционированных и непреднамеренных воздействий на неё. Под утечкой понимают неконтролируемое распространение защищаемой информации путём её разглашения или несанкционированного доступа к ней. Несанкционированный доступ (воздействие) – это доступ (воздействие) с нарушением правил доступа, например, взлом административной базы данных, внедрение вируса или подмена электронного документа.

Под непреднамеренным воздействием на защищаемую информацию понимают воздействие на неё из-за ошибок пользователя, сбоя технических или программных средств, иных нецеленаправленных действий.

Целью защиты информации является предотвращение ущерба собственнику, владельцу или пользователю информации. Под эффективностью защиты информации понимают степень соответствия результатов защиты информации поставленной цели. Объектом защиты может быть информация, её носитель или информационный процесс, в отношении которых необходимо обеспечить защиту в соответствии с поставленной целью.

Политика безопасности – это набор документированных норм, правил и практических приёмов, регулирующих управление, защиту и распределение информации ограниченного доступа.

п.2. Характеристики информации, применительно к задачам защиты.

Информация обладает довольно большим набором характеристик, но с точки зрения информационной безопасности следует обратить внимание на следующие параметры любой информационной единицы: статичность; размер и тип доступа; время жизни; стоимость создания; стоимость потери конфиденциальности; стоимость скрытого нарушения целостности; стоимость утраты.

Статичность определяет, может ли защищаемая информация изменяться в процессе нормального использования. Например, данные в защищённой базе данных могут изменяться в каждом сеансе работы, а передаваемое по сети зашифрованное сообщение меняться не должно.

Размер единицы защищаемой информации может накладывать дополнительные ограничения на используемые средства защиты, например, некоторые алгоритмы используют блоки информации определённого размера. Тип доступа – последовательный или произвольный – также накладывает ограничения на выбор средств защиты.

Время жизни информации – промежуток времени, пока информация актуальна. Это очень важный параметр, который определяет, как долго информация должна оставаться защищённой. Обычно время жизни персональной информации (банковская, медицинская и т.п.) соответствует времени жизни её владельца. После его смерти она никому не принесёт ни пользы, ни вреда. Для государственных секретов определяется промежуток времени, в течение которого она не должна стать публичной (гриф "секретно"). Для некоторых документов этот срок неограничен. Также никогда не должна разглашаться информация о ключах шифрования, вышедших из употребления, т.к. у противника могут быть старые, зашифрованные с использованием этого ключа, сообщения, ещё представляющие интерес.

Стоимость создания является денежным выражением совокупности всех затраченных на создание информации ресурсов: финансовых, человеческих, временных. Стоимость создания фактически совпадает с себестоимостью информации.

Стоимость потери конфиденциальности выражает потенциальные убытки, которые понесёт владелец информации, если к ней получат неавторизованный доступ сторонние лица. Обычно, стоимость потери конфиденциальности многократно превышает себестоимость информации. По истечении времени жизни информации стоимость потери её конфиденциальности становится равной нулю.

Стоимость скрытого нарушения целостности выражает убытки, которые могут возникнуть вследствие внесения изменений в информацию, если факт модификации не обнаружен. Нарушения целостности могут быть как случайными, так и преднамеренными. Изменению могут подвергаться не только сам текст сообщения, но и дата отправки или имя автора.

Стоимость утраты описывает ущерб от полного или частичного разрушения информации. При обнаружении нарушения целостности и невозможности получить ту же информацию из другого источника информация считается утраченной.

Указанные четыре вида стоимости могут по-разному соотноситься друг с другом. Для примера рассмотрим смарт-карту, на которой находится специальный ключ криптографической системы, используемый для подписи сообщений. Стоимость создания такой карты сравнительно мала (печатная плата + пластиковая оболочка). В случае потери конфиденциальности, например, противнику удалось скопировать секретный ключ, или получить неограниченный доступ к самой карте, или создать её точную копию, могут быть очень тяжёлые последствия: противник может создавать ложные сообщения и подписывать их настоящей подписью. Скрытое нарушение целостности практически не имеет смысла, так испорченная подпись будет сразу замечена. Также несущественна стоимость утраты карты. Поэтому современные смарт-карты не позволяют прочесть секретный ключ стандартными средствами, а при попытке физического вмешательства во "внутренности" карты, данные просто уничтожаются.

п.3. Информационная безопасность в условиях функционирования в России глобальных сетей.

Главной целью создания сети Интернет было обеспечение функциональности при выходе из строя одного или нескольких ее узлов, цель в общем состояла в обеспечении безопасности. Однако, исходно сеть создавалась как незащищенная открытая система, предназначенная для информационного общения все возрастающего числа пользователей. При этом подключение новых пользователей должно было быть максимально простым, а доступ к информации - наиболее удобным. Все это явно противоречит принципам создания защищенной системы, безопасность которой должна быть описана на всех стадиях ее создания и эксплуатации, а пользователи - наделены четкими полномочиями.

Internet создавался как незащищенная система, не предназначенная для

хранения и обработки конфиденциальной информации. Следовательно, протоколы используемые в этой сети также не обеспечивают должного контроля безопасности и целостности информационных ресурсов. В Сети не должна находиться информация, раскрытие которой приведет к серьезным последствиям. Наоборот, в Сети необходимо размещать информацию, распространение которой желательно ее владельцу. При этом всегда необходимо учитывать тот факт, что в любой момент эта информация может быть перехвачена, искажена или может стать недоступной. Следовательно, особое внимание должно быть уделено информационной безопасности в условиях функционирования глобальных сетей. В России данная проблема особенно актуальна, так как в нашей стране не развита соответствующим образом ни законодательная, ни программная, ни аппаратная база.

По оценке экспертов самым привлекательным сектором российской экономики для преступников является кредитно-финансовая система. При совершении преступных деяний наметились определённые тенденции:

1. Большинство компьютерных преступлений в России и за рубежом совершаются путём несанкционированного доступа к банковским базам данных посредством телекоммуникационных сетей, чаще всего с использованием возможностей, которые предоставляет сеть Internet.

2. Абсолютное большинство преступлений совершается преступными группировками, состоящими из "хакерской бригады" и охранной команды, со специально подготовленного плацдарма (отдельной квартиры, офиса и т.п.). Для успешной атаки очень часто привлекаются служащие атакуемого учреждения (подкуп, шантаж и т.д.)

Уникальное положение сети Internet, которая не принадлежит одному владельцу, позволяет использовать её возможности в различных криминальных направлениях:

1. Сеть Internet используется в качестве среды для преступной деятельности, в основном для обмена информацией и налаживания контактов.

2. Служит информационной средой, в которой осуществляется глобальное информационно-психологическое воздействие.

3. Является инструментом для совершения преступлений.

Наиболее распространённые правонарушения:

- a. Проникновение в кредитно-финансовую систему, с целью доступа к конфиденциальной информации (получение данных, их изменение или уничтожение).

- b. Хищения электронной наличности.

- c. Нарушение авторских прав.

- d. Нелегальное получение товаров и услуг (например, бесплатные телефонные разговоры).

- e. Мошенническая деятельность (финансовые пирамиды, фиктивные фирмы и т.п.).

- f. Нарушение законов, связанных с ограничением азартных игр.

Тема 2. Задачи и методы информационной безопасности.

п.1. Основные задачи информационной безопасности.

Задачи информационной безопасности (да и безопасности любого другого рода) сводятся, как правило, к минимизации ущерба при возможных воздействиях, а также к предсказанию и предотвращению таких воздействий.

Соответственно, составляющими информационной безопасности являются:

- определение объектов, на которые могут быть направлены угрозы;
- выявление существующих и возможных угроз;
- определение возможных источников угрозы;
- оценка рисков;
- методы и средства обнаружения враждебного воздействия;
- методы и средства защиты от известных угроз;
- методы и средства реагирования при инцидентах.

Вкратце все это можно сформулировать в трех предложениях. Основными задачами информационной безопасности являются:

Секретность (privacy, confidentiality, secrecy) – одна из самых востребованных задач. Пока для хранения используются неэлектронные средства, секретность обеспечивается административными мерами. При переносе на компьютер и передачи по электронным каналам связи задействуются методы информационной безопасности. Задача обеспечения секретности сводится к тому, чтобы сделать возможным и передачу данных в таком виде, чтобы противник, даже получив доступ к носителю или среде передачи, не смог получить защищённые данные.

Целостность (data integrity) – ещё одна наиболее важная задача. В процессе обработки и передачи по каналам связи данные могут быть искажены, как случайно, так и преднамеренно. Также информация может быть изменена прямо на носителе, где она храниться. Проверка целостности строго необходима в ситуациях, когда интерпретация неправильных данных может привести к очень серьёзным последствиям, например, при возникновении в ошибке банковского счёта. Обеспечение целостности заключается в том, чтобы позволить либо утверждать, что данные не были модифицированы при хранении и передаче, либо определить факт искажения данных.

Идентификация (identification) – необходима для того, чтобы отождествить пользователя с некоторым уникальным идентификатором. После этого ответственность за все действия в системе, которой принадлежит идентификатор, возлагаются на пользователя, за которым этот идентификатор закреплён.

Аутентификация (data origin, authentication) – является необходимым дополнением к идентификации и предназначена для подтверждения истинности пользователя, предъявившего идентификатор. Неанонимный пользователь при доступе к очень важной информации должен получить возможность работать только после успешной аутентификации.

Уполномочивание (authorization) – сводится к тому, что ни один пользователь не должен получить доступ к системе без успешного

выполнения идентификации и последующей аутентификации и ни один пользователь не должен получить доступ к ресурсам, если он не уполномочен на такие действия специальным разрешением.

Контроль доступа (access control) – комплексное понятие, обозначающее совокупность методов и средств, предназначенных для ограничения доступа к ресурсам. Доступ должны иметь только уполномоченные пользователи, а попытки доступа должны протоколироваться.

Право собственности (ownership) – используется для того, чтобы предоставить пользователю право на использование некоторого ресурса и, при желании, возможность передачи этого ресурса в собственность другому пользователю. Право собственности обычно является составной частью системы контроля доступа.

Сертификация (certification) – процесс подтверждения некоторого факта стороной, которой пользователь доверяет. Чаще всего сертификация используется для удостоверения принадлежности открытого ключа конкретному пользователю или компании, т.к. эффективное использование инфраструктуры открытых ключей возможно лишь при наличии системы сертификации. Организации, занимающиеся выдачей сертификатов, называются удостоверяющими центрами.

Подпись (signature) – позволяет получателю документа доказать, что данный документ был подписан именно отправителем. При этом должно учитываться, что подпись не может быть перенесена на другой документ, отправитель не может отказаться от своей подписи, любое изменение документа приведёт к нарушению подписи, а любой пользователь может самостоятельно убедиться в подлинности подписи.

Неотказуемость (non-repudiation) – свойство схемы информационного обмена, при котором существует доказательство, которое получатель сообщения способен предъявить третьей стороне, чтобы та смогла независимо проверить, кто является отправителем сообщения, т.е. отправитель не имеет возможности отказаться от авторства своего сообщения.

Датирование (time stamping) – часто применяется совместно с подписью и позволяет зафиксировать момент подписания документа. Это может быть полезно, например, для доказательства первенства, если один документ был подписан несколькими пользователями, каждый из которых утверждает, что именно является автором документа. Кроме этого датирование широко используется в сертификатах, которые имеют ограниченный срок действия.

Расписка в получении (receipt) – передаётся от получателя к отправителю и может впоследствии быть использована отправителем для доказательства того, что переданная информация была доставлена получателю не позже определённого момента, указанного в расписке.

Аннулирование (annul) – используется для отмены действия сертификатов, полномочий или подписей. Если какой-либо участник информационного обмена или принадлежащие ему ключи и сертификаты оказались скомпрометированы, необходимо предотвратить доступ этого пользователя к ресурсам и отказать в доверии соответствующему сертификату.

Анонимность (anonymity) – довольно редко используемая задача. Правительствам и корпорациям не выгодно, чтобы пользователь мог остаться

анонимным при совершении каких-либо действий в информационном пространстве.

Свидетельствование (witnessing) – удостоверение (подтверждение) факта создания или существования информации некоторой стороной, не являющейся создателем.

п.2. Основные методы обеспечения защиты информационной системы.

Возможные методы защиты информации почти всегда определяются формой её представления и предполагаемыми способами использования. Методы защиты информации можно разбить на три большие группы: законодательные, административные и технические.

Законодательно-правовой уровень включает комплекс законодательных и иных правовых актов, устанавливающих правовой статус субъектов информационных отношений, субъектов и объектов защиты, методы, формы и способы защиты, их правовой статус. Кроме того, к этому уровню относятся стандарты и спецификации в области информационной безопасности. Система законодательных актов и разработанных на их базе нормативных и организационно-распорядительных документов должна обеспечивать организацию эффективного надзора за их исполнением со стороны правоохранительных органов и реализацию мер судебной защиты и ответственности субъектов информационных отношений. К этому уровню можно отнести и морально-этические нормы поведения, которые сложились традиционно или складываются по мере распространения вычислительных средств в обществе. Морально-этические нормы могут быть регламентированными в законодательном порядке, т. е. в виде свода правил и предписаний. Наиболее характерным примером таких норм является Кодекс профессионального поведения членов Ассоциации пользователей ЭВМ США. Тем не менее, эти нормы большей частью не являются обязательными, как законодательные меры.

Законодательные методы определяют, кто и в какой форме должен иметь доступ к защищаемой информации, и устанавливают ответственность за нарушения установленного порядка. В современном мире существует множество подобных законов: закон о защите государственной тайны, закон о защите авторских прав, положение о праве на тайну личной переписки и т.д. Законодательные методы не способны гарантировать выполнение установленных правил, они лишь декларируют эти правила вместе с мерой ответственности за их нарушения.

Административный уровень включает комплекс взаимокоординируемых мероприятий и технических мер, реализующих практические механизмы защиты в процессе создания и эксплуатации систем защиты информации. Организационный уровень должен охватывать все структурные элементы систем обработки данных на всех этапах их жизненного цикла: строительство помещений, проектирование системы, монтаж и наладка оборудования, испытания и проверки, эксплуатация.

Административные методы определяют процедуры доступа к защищаемой информации и строго следят за их выполнением. Контроль за соблюдением установленного порядка возлагается на специально обученный персонал. При применении административных методов на любом этапе работы известно лицо, несущее ответственность за целостность и секретность охраняемого документа. Административные методы очень часто совмещаются с законодательными и могут устанавливать ответственность за попытки нарушения установленных процедур доступа.

Программно-технический уровень включает три подуровня: физический, технический (аппаратный) и программный. Физический подуровень решает задачи с ограничением физического доступа к информации и информационным системам, соответственно к нему относятся технические средства, реализуемые в виде автономных устройств и систем, не связанных с обработкой, хранением и передачей информации: система охранной сигнализации, система наблюдения, средства физического воспрепятствования доступу (замки, ограждения, решетки и т. д.).

Средства защиты аппаратного и программного подуровней непосредственно связаны с системой обработки информации. Эти средства либо встроены в аппаратные средства обработки, либо сопряжены с ними по стандартному интерфейсу. К аппаратным средствам относятся схемы контроля информации по четности, схемы доступа по ключу и т. д. К программным средствам защиты, образующим программный подуровень, относятся специальное программное обеспечение, используемое для защиты информации, например антивирусный пакет и т. д. Программы защиты могут быть как отдельные, так и встроенные. Так, шифрование данных можно выполнить встроенной в операционную систему файловой шифрующей системой EFS (Windows 2000, XP) или специальной программой шифрования.

Подчеркнем, что формирование режима информационной безопасности является сложной системной задачей, решение которой в разных странах отличается по содержанию и зависит от таких факторов, как научный потенциал страны, степень внедрения средств информатизации в жизнь общества и экономику, развитие производственной базы, общей культуры общества и, наконец, традиций и норм поведения.

Технические методы защиты, в отличие от законодательных и административных, призваны максимально избавиться от человеческого фактора. В случае применения технических средств защиты перед потенциальным противником ставится некоторая техническая (математическая, физическая, технологическая) задача. В то же время легитимному пользователю доступен более простой путь, позволяющий работать с предоставленной в его распоряжение информацией без решения сложных задач.

Технические методы защиты призваны обеспечить решение всех задач, перечисленных выше. Условно методы решения этих задач можно разделить на те, которые имеют математическое обоснование стойкости к взлому, и те, которые такого обоснования не имеют.

Методы, не имеющие математического обоснования стойкости, часто называют методами с "чёрным ящиком". "Чёрный ящик" – некоторое

устройство, которому на вход подаются данные, а на выходе снимается результат. Процесс, происходящий внутри, предполагается неизвестным ни пользователю, ни потенциальному противнику. При вскрытии самого "ящика" стойкость системы защиты становится равной нулю. Методы, функционирующие по принципу "черного ящика", называют Security Through Obscurity – безопасность через неясность.

Особенность методов защиты, имеющих математическое обоснование стойкости, заключается в том, что их надёжность оценивается, исходя из предположения открытости внутренней структуры. То есть предполагается, что потенциальному противнику в подробностях известен алгоритм работы и протоколы, используемые для обеспечения защиты, но противник не в состоянии обойти защиту, т.к. на момент атаки ему надо решить некую сложную математическую задачу, которая на данный момент не имеет эффективного решения. Большинство методов, имеющих математическое обоснование стойкости, относятся к методам криптографии.

Также методы, используемые для обеспечения информационной безопасности, могут быть квалифицированы следующим образом:

- **препятствие** – метод физического преграждения пути злоумышленнику к информации;
- **управление доступом** – метод защиты с помощью регулирования использования информационных ресурсов системы;
- **маскировка** – метод защиты информации путем ее криптографического преобразования;
- **регламентация** – метод защиты информации, создающий условия автоматизированной обработки, при которых возможности несанкционированного доступа сводятся к минимуму;
- **принуждение** – метод защиты, при котором персонал вынужден соблюдать правила обработки, передачи и использования информации;
- **побуждение** – метод защиты, при котором пользователь побуждается не нарушать режимы обработки, передачи и использования информации за счет соблюдения этических и моральных норм.

Тема 3. Угрозы информационной безопасности.

п.1. Ключевые свойства информации. Понятие угрозы.

Основными характеристиками защищаемой информации являются конфиденциальность, целостность и доступность.

Конфиденциальность информации – это известность её содержания только имеющим соответствующие полномочия субъектам. Конфиденциальность является субъективной характеристикой информации, связанной с объективной необходимостью защиты законных интересов одних субъектов от других.

Целостностью информации называют неизменность информации в условиях её случайного и (или) преднамеренного искажения и разрушения. Целостность – свойство актуальности и непротиворечивости информации. Целостность является частью более широкой характеристики информации – её достоверности, включающей также полноту и точность отображения предметной области.

Доступность – возможность получения информации или информационной услуги за приемлемое время. Также под доступностью информации понимают способность обеспечения беспрепятственного доступа легитимных пользователей к интересующей их информации.

Угроза информационной безопасности – потенциально возможное событие, действие, процесс или явление, которое может привести к изменению функционирования компьютерной системы. Уязвимость информации – это возможность возникновения на каком-либо этапе жизненного цикла компьютерной системы такого её состояния, при котором создаются условия для реализации угроз безопасности информации.

Попытка реализации угрозы называется атакой. Другими словами, атака на компьютерную систему – это действия, предпринимаемые злоумышленником, которые заключаются в поиске и использовании уязвимостей информации.

Классификацию угроз ИБ можно выполнить по нескольким критериям:

- по аспекту информационной безопасности (доступность, целостность, конфиденциальность) – основная классификация;
- по компонентам информационной системы, на которые угрозы нацелены (данные, программа, аппаратура, поддерживающая инфраструктура);
- по способу осуществления (случайные или преднамеренные действия, природного или техногенного характера);
- по расположению источника угроз (внутри или вне рассматриваемой информационной системы).

Угрозы информационной безопасности могут быть разделены на угрозы, не зависящие от деятельности человека (естественные угрозы физических воздействий на информацию стихийных природных явлений), и угрозы, вызванные человеческой деятельностью (искусственные угрозы), которые являются гораздо более опасными.

Искусственные угрозы исходя из их мотивов разделяются на непреднамеренные (случайные) и преднамеренные (умышленные). К непреднамеренным угрозам относятся:

- ошибки в проектировании КС;
- ошибки в разработке программных средств КС;
- случайные сбои в работе аппаратных средств КС, линий связи, энергоснабжения;
- ошибки пользователей КС;
- воздействие на аппаратные средства КС физических полей других электронных устройств (при несоблюдении условий их электромагнитной совместимости) и др.

К умышленным угрозам относятся:

- несанкционированные действия обслуживающего персонала КС (например, ослабление политики безопасности администратором, отвечающим за безопасность КС);
- несанкционированный доступ к ресурсам КС со стороны пользователей КС и посторонних лиц, ущерб от которого определяется полученными нарушителем полномочиями.

В зависимости от целей преднамеренных угроз безопасности информации в КС угрозы могут быть разделены на три основные группы:

- угроза нарушения конфиденциальности, т. е. утечки информации ограниченного доступа, хранящейся в КС или передаваемой от одной КС к другой;
- угроза нарушения целостности, т. е. преднамеренного воздействия на информацию, хранящуюся в КС или передаваемую между КС
- угроза нарушения доступности информации, т. е. отказа в обслуживании, вызванного преднамеренными действиями одного из пользователей КС (нарушителя), при котором блокируется доступ к некоторому ресурсу КС со стороны других пользователей КС (постоянно или на большой период времени).

п.2. Угроза нарушения конфиденциальности.

Часть информации, хранящейся и обрабатываемой в ИС, должна быть сокрыта от посторонних. Передача данной информации может нанести ущерб, как организации, так и самой информационной системе. Таким образом, угроза нарушения конфиденциальности – это угроза утечки информации ограниченного доступа, хранящейся в информационной системе или передающейся по каналам связи.

Конфиденциальная информация может быть разделена на предметную и служебную. Служебная информация (например, пароли пользователей) не относится к определенной предметной области, однако ее раскрытие может привести к несанкционированному доступу ко всей информации.

Предметная информация содержит информацию, раскрытие которой может привести к ущербу (экономическому, моральному) организации или лица.

Средствами атаки могут служить различные технические средства (подслушивание разговоров, сети), другие способы (несанкционированная передача паролей доступа и т.п.).

Важный аспект – непрерывность защиты данных на всем жизненном цикле ее хранения и обработки. Т.е. если существует несколько копий некоторой информационной единицы или одна копия передаётся от одного субъекта к другому, то применяемая защита должна быть равнозначна. Пример нарушения – доступное хранение резервных копий данных.

п.3. Угроза нарушения целостности.

Одними из наиболее часто реализуемых угроз ИБ являются кражи и подлоги. В информационных системах несанкционированное изменение информации может привести к потерям. Санкционированным является действие с информацией, сделанное уполномоченным лицом с обоснованной целью. Таким образом, угроза нарушения целостности – это угроза преднамеренного воздействия на информацию, хранящуюся в информационной системе или передаваемую по каналам связи. Отметим также, что целостность информации может быть нарушена и при неверной работе аппаратных или программных средств, но эта ситуация относится к угрозе отказа служб.

Целостность информации может быть разделена на статическую и динамическую.

Примерами нарушения статической целостности являются:

- ввод неверных данных;
- несанкционированное изменение данных;
- изменение программного модуля вирусом;

Примеры нарушения динамической целостности:

- нарушение атомарности транзакций;
- дублирование данных;
- внесение дополнительных пакетов в сетевой трафик.

п.4. Угроза отказа служб.

Отказ служб (отказа в доступе к информационной системе) относится к одним из наиболее часто реализуемых угроз. Относительно компонент информационной системы данный класс угроз может быть разбит на следующие типы:

- отказ пользователей (нежелание, неумение работать с ИС).

Устраняется административно-правовыми методами.

- внутренний отказ информационной системы (ошибки при переконфигурировании системы, отказы программного и аппаратного обеспечения, разрушение данных). Невозможно предотвратить стандартными методами защиты информации, но можно минимизировать последствия (резервное копирование и т.п.).

- отказ поддерживающей инфраструктуры (нарушение работы систем связи, электропитания, разрушение и повреждение помещений).

Тема 4. Потенциальные противники и атаки.

п.1. Виды противников или "нарушителей".

"Нарушители" классифицируются по одному из следующих критериев:

- уровень профессиональной подготовки противника и его потенциальных возможностей (обычные пользователи, профессионалы (хакеры) и правительственные агентства крупных мировых держав). Этот критерий зачастую является ключевым при определении потенциальных угроз;

- тип доступа противника к системе (внешний или внутренний), а также объём доступной для злоумышленника информации (общедоступная, внутренняя (корпоративная), закрытая);

- способы атаки, доступные противнику и наиболее часто применяемые им.

Классификации по этим критериям достаточно условны и в большинстве случаев пересекаются.

Обычный пользователь вряд ли может нанести серьёзный ущерб информационной системе, весомую угрозу представляет только внутренний доступ (т.е. работник организации, эксплуатирующей ИС). Обычные пользователи чаще всего пользуются готовыми программами, написанными профессионалами и находящиеся в открытом доступе. Эту категорию обычно составляют обиженные работники и студенты.

Гораздо более опасными являются хакеры. Будем называть хакером высококвалифицированного специалиста стремящегося обойти защиту компьютерной системы, вне зависимости от того, получает ли он от этого коммерческую выгоду, и преследуются ли по закону его действия. Для действий хакера характерны следующие особенности:

- он всегда в курсе любых компьютерных новинок, является высококлассным программистом, отлично разбирается в архитектуре вычислительных машин и систем связи.

- перед атакой собирает информацию об атакуемой системе всеми доступными способами, в том числе агентурными и оперативно-техническими. Перед попыткой взлома часто создает макет системы для отработки действий.

- сама атака осуществляется быстро, с использованием простых и эффективных методов, чтобы администраторы системы не успели заметить атаку и отследить противника. В большинстве случаев имеется тщательно продуманный план замести следы и скрыть свои реальные данные.

- в большинстве случаев использует собственноручно написанные программы, которые создаются заранее, и чаще всего внедряются в атакуемую систему заблаговременно.

Правительственные агентства представляют наибольшую угрозу, т.к. обладают большими вычислительными мощностями, позволяющим на параллельных процессорах осуществлять полный перебор ключа. Кроме этого, правительственные агентства обладают необходимыми финансовыми возможностями.

Например, для взлома алгоритма шифрования DES (Data Encryption Standard), который имеет рабочую длину 56 бит, надо перебрать, соответственно, 2^{56} возможных ключей. Причём ограничение в длине было введено АНБ (Агентство Национальной Безопасности США). Этот алгоритм является стандартом шифрования во всех правительственных несекретных каналах связи. Для расшифровки сообщения полным перебором в январе 1999 года было совместно использовано 100 тысяч персональных компьютеров и специальный компьютер, построенный организацией EFF по заказу АНБ за сумму 250 тысяч долларов. Шифр был взломан за 22 часа. С 1999 года мощности компьютеров выросли в несколько раз, хотя взлом DES на персональном компьютере полным перебором пока невозможен.

п.2. Виды и каналы утечки информации.

Под утечкой информации понимают её неконтролируемое копирование.

Каналы утечки информации делятся на два больших класса: косвенные и непосредственные.

Косвенными каналами утечки называют каналы, не связанные с физическим доступом к элементам информационной системы. К ним относятся: использование полущивающих устройств; дистанционное видеонаблюдение; перехват побочных электромагнитных излучений и наводок.

Побочные электромагнитные излучения создаются техническими средствами компьютерной системы при обработке информации, существуют в

диапазоне от 1 герц до 1, 5 ГГц и могут распространять обрабатываемую информацию на дальности до 1 км.

Непосредственные каналы связаны с непосредственным физическим доступом к элементам ИС, и, в свою очередь подразделяются на:

1. каналы, не требующие изменения элементов ИС;
2. каналы, предполагающие изменение элементов ИС и её структуры.

К первому типу относятся:

- а. хищение носителей информации;
- б. сбор производственных отходов с информацией;
- в. намеренное копирование файлов и носителей информации;
- г. чтение остаточной информации после выполнения заданий другими пользователями;
- д. намеренное использование незаблокированных терминалов других пользователей;
- е. маскировка под других пользователей, путём похищение идентифицирующей их информации;
- ж. обход средств разграничения доступа, используя их недостатки.

Ко второму типу относятся:

- а. незаконное подключение специальной регистрирующей аппаратуры к устройствам связи;
- б. злоумышленное изменение программ для выполнения ими несанкционированного копирования информации при её обработке.
- в. злоумышленный вывод из строя средств защиты информации.

Наличие в информационной системе значительного числа потенциальных каналов утечки информации увеличивает общую уязвимость информации.

п.3. Классификация атак.

Классификация атак на информационную систему может быть выполнена по нескольким признакам.

По месту возникновения:

- локальные атаки (источником данного вида атак являются пользователи и/или программы локальной системы);
- удаленные или сетевые атаки (источником атаки выступают удаленные пользователи, сервисы или приложения).

По воздействию на информационную систему:

- активные атаки, результатом воздействия которых является нарушение деятельности информационной системы;
- пассивные атаки, ориентированные на получение информации из системы, не нарушая функционирование информационной системы.

При классификации атак экономических информационных систем, рассматривают направленность атак по основным компонентам ЭИС:

- атаки на уровне операционной системы;
- атаки на уровне сетевого программного обеспечения;
- атаки на уровне систем управления базами данных.

Защита СУБД является одной из самых простых задач, т.к. СУБД имеет строго определённую внутреннюю структуру, и операции над элементами заданы чётко. А так как большую часть операций составляют наборы всего 4

операций: поиск, вставка, удаление и замена элемента, то подобная высокая структурированность позволяет четко отслеживать все действия пользователей и обеспечивать высокий уровень защиты. Поэтому хакеры предпочитают атаковать СУБД с помощью средств операционной системы, предварительно взломав последнюю. Непосредственным атакам подвергаются только плохо спроектированные БД, имеющие низкий уровень защиты. При этом наиболее часто встречаются два типа специфических атак: 1. округление счётов в меньшую сторону с переводом остатка на другой счёт; 2. доступ к статистической информации с помощью специального запроса, создающего одну запись-ответ.

Защита операционной системы является гораздо более трудной задачей, т.к. внутренняя структура современной операционной системы чрезвычайно сложна. Однако, сами атаки являются предельно простыми, чтобы минимизировать вероятность сбоев и ошибок. Алгоритм атаки существенно зависит от типа операционной системы, но существует ряд атак, которым подвержены практически любые операционные системы:

- кража пароля (получение из вспомогательных файлов, подглядывание, клавиатурные шпионы, полный перебор, подбор по данным пользователя);
- сканирование жёстких дисков и сборка "мусора" (восстановление удалённых файлов, проверка резервных копий и т.п.);
- превышение полномочий (запуск программ от имени другого пользователя, подмена динамических библиотек, модификация кода или данных подсистемы защиты);
- отказ в обслуживании (захват ресурсов с помощью хакерских программ, бомбардировка запросами, использование ошибок в программном обеспечении).

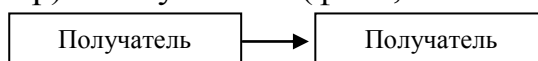
п.4. Сетевые атаки.

Атаки на уровне сетевого программного обеспечения являются наиболее эффективными, т.к. каналы связи обычно бывают практически не защищёнными. Для сетевых атак понятие пассивной и активной атаки несколько уточняются:

Пассивной называется такая атака, при которой противник не имеет возможности модифицировать передаваемые сообщения и вставлять в информационный канал между отправителем и получателем свои сообщения.

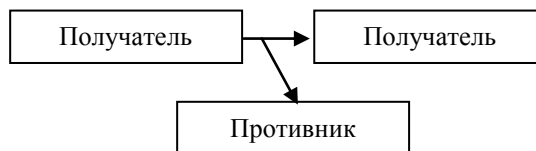
Активной называется такая атака, при которой противник имеет возможность модифицировать передаваемые сообщения и вставлять свои сообщения. Различают следующие типы активных атак.

При описании сетевых атак в общем случае используется следующее представление: существует информационный поток от отправителя (файл, пользователь, компьютер) к получателю (файл, пользователь, компьютер):

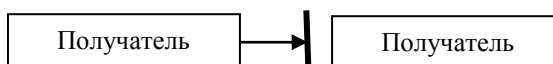


Рассматриваются следующие типы атак:

Пассивная атака или нелегитимное копирование. Целью пассивной атаки может быть только прослушивание передаваемых сообщений и анализ трафика.

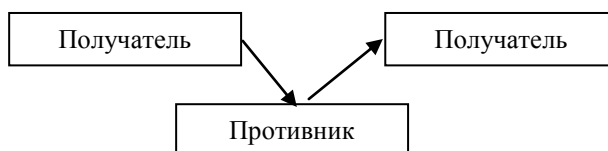


Отказ в обслуживании (DoS-атака, Denial of Service) – нарушает нормальное функционирование сетевых сервисов. Противник может перехватывать все сообщения, направляемые определенному адресату. Другим примером подобной атаки является создание значительного трафика, в результате чего сетевой сервис не сможет обрабатывать запросы законных клиентов. Классическим примером такой атаки в сетях TCP/IP является SYN-

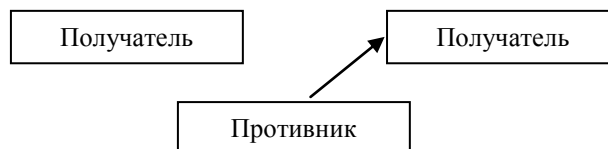


атака, при которой нарушитель посылает пакеты, инициирующие установление TCP-соединения, но не посылает пакеты, завершающие установление этого соединения. В результате может произойти переполнение памяти на сервере, и серверу не удастся установить соединение с законными пользователями.

Модификация потока данных – атака "man in the middle" – означает либо изменение содержимого пересылаемого сообщения, либо изменение порядка сообщений.

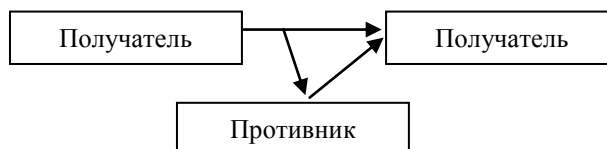


Создание ложного потока (фальсификация, нарушение



аутентичности) – означает попытку одного субъекта выдать себя за другого.

Повторное использование – означает пассивный захват данных с последующей их пересылкой для получения несанкционированного доступа - это так называемая replay-атака. На самом деле replay-атаки являются одним из вариантов фальсификации, но в силу того, что это один из наиболее распространенных вариантов атаки для получения несанкционированного доступа, его часто рассматривают как отдельный тип атаки.



Тема 5. Основные положения теории информационной безопасности информационных систем.

п.1. Подходы к обеспечению информационной безопасности.

На сегодняшний день сеть Интернет становится неотъемлемой частью ведения бизнеса, позволяющей работать с большими массивами информации

и осуществлять мгновенную коммуникацию с географически разрозненными регионами. Глобальная сеть Интернет стала универсальным средством связи и общения. Вместе с тем, Интернет является очень трудно контролируемым каналом распространения информации, что приводит к тому, что средства World Wide Web нередко используются для получения несанкционированного доступа к конфиденциальной и закрытой коммерческой информации со стороны злоумышленников и различного рода мошенников. Сеть Интернет играет существенную роль и в так называемой «конкурентной» разведке – сборе сведений о действиях и планах конкурирующих организаций с целью дальнейшего ослабления их рыночных позиций. Различного рода информационные угрозы для деятельности предприятия могут создаваться как единичными мошенниками или хулиганствующими непрофессиональными субъектами, так и мощными, высокопрофессиональными организациями, задействованными в многоуровневых стратегиях конкурентной борьбы.

Для защиты АИС могут быть сформулированы следующие положения:

- Информационная безопасность основывается на положениях и требованиях существующих законов, стандартов и нормативно-методических документов;
- Информационная безопасность АИС обеспечивается комплексом программно-технических средств и поддерживающих их организационных мероприятий;
- Информационная безопасность АИС должна обеспечиваться на всех этапах технологической обработки данных и во всех режимах функционирования, в том числе при проведении ремонтных и регламентных работ;
- Программно-технические средства защиты не должны существенно ухудшать основные функциональные характеристики АИС;
- Неотъемлемой частью работ по информационной безопасности является оценка эффективности средств защиты, осуществляемая по методике, учитывающей всю совокупность технических характеристик оцениваемого объекта, включая технические решения и практическую реализацию;
- Защита АИС должна предусматривать контроль эффективности средств защиты. Этот контроль может быть периодическим или иницилируемым по мере необходимости пользователем АИС.

п.2. Принципы обеспечения информационной безопасности.

а. *Системность* – при разработке и реализации систем защиты информации предполагает определение возможных угроз информационной безопасности и выбор методов и средств, направленных на противодействие данному комплексу угроз. При этом выбранное решение должно включать набор мероприятий, противодействующий всему комплексу угроз.

б. *Комплексность*. При решении вопросов обеспечения информационной безопасности необходимо ориентироваться на весь набор средств защиты данных – программные, технические, правовые, организационные и т.д.

в. *Непрерывность* – предполагает, что комплекс мероприятий по обеспечению информационной безопасности должен быть непрерывен во

времени и пространстве, т.е. защита информационных объектов должна обеспечиваться и при выполнении регламентных и ремонтных работ, во время настройки и конфигурирования информационных систем и сервисов и т.п.

г. *Разумная достаточность*. Невозможно создать абсолютно надёжную и всеобъемлющую систему защиты. При этом построение и обслуживание даже частичной системы защиты требует определённых затрат. Поэтому при выборе системы защиты необходимо найти компромисс между затратами на защиту информационных объектов и возможными потерями при реализации информационных угроз.

д. *Гибкость управления и применения*. Угрозы информационной безопасности многогранны и заранее точно не определены. Для успешного противодействия необходимо наличие возможности изменения применяемых средств, оперативного включения или исключения используемых средств защиты данных, добавления новых механизмов защиты.

е. *Открытость алгоритмов и механизмов защиты*. Средства информационной безопасности сами могут представлять собой угрозу информационной системе или объекту. Для предотвращения такого класса угроз необходимо, чтобы алгоритмы и механизмы защиты допускали независимую проверку на безопасность и следование стандартам. Также требуется проверка возможности применения алгоритмов и механизмов защиты в совокупности с другими средствами защиты данных.

ж. *Простота применения защитных мер и средств*. При проектировании систем защиты информации необходимо помнить, что реализация предлагаемых мер и средств будет проводится пользователями (часто не являющихся специалистами в области ИБ). Поэтому для повышения эффективности мер защиты необходимо, чтобы алгоритм работы с ними был понятен пользователю. Кроме того, используемые средства и механизмы информационной безопасности не должны нарушать нормальную работу пользователя с автоматизированной системой (резко снижать производительность, повышать сложность работы и т.п.).

п.3. Формальные модели доступа к данным.

Механизмы управления доступом являются основой защиты ресурсов, обеспечивая решение задачи разграничения доступа субъектов (пользователей или процессов) к защищаемым информационным и техническим ресурсам – объектам. Механизм управления доступом реализует на практике некоторую абстрактную или формальную модель, определяющую правила задания разграничительной политики доступа к защищаемым ресурсам и правила обработки запросов доступа к защищаемым ресурсам.

В литературе описаны следующие формальные модели доступа к данным: модель Биба, модель Гогена-Мезигера, сазерлендская модель, модель Кларка-Вильсона, дискреционная (матричная) модель, многоуровневая (мандатная) модель.

Самой распространённой на практике является дискреционная модель. В её основе лежат следующие положения:

- все субъекты и объекты должны быть идентифицированы;

- права доступа субъекта к объекту системы определяются на основании некоторого внешнего правила.

Отношения «субъекты-объекты» можно представить в виде матрицы доступа, в строках которой перечислены субъекты, в столбцах объекты ИС, а в клетках, на пересечении строк и столбцов, записаны дополнительные условия и разрешенные виды доступа. Таким образом, реализация управления доступом заключается в проверке строк матрицы, соответствующей объекту и анализируются права доступа к этому объекту для текущего субъекта.

Достоинство модели – относительно простая реализация соответствующих механизмов защиты. Недостатки – статичность модели и излишне детализированный уровень описания отношений субъектов и объектов, как следствие, усложнение администрирования и возникновение ошибок.

С целью устранения недостатков матричных моделей были разработаны многоуровневые модели (Белла и Ла-Падулы, решетчатая модель Деннинга). Многоуровневые модели защиты находятся гораздо ближе к потребностям реальной жизни, чем матричные, представляют собой Лучшую основу для построения автоматизированных систем разграничения доступа.

Мандатное управление доступом, включает следующие требования:

- все субъекты и объекты ИС должны быть однозначны идентифицированы;
- задан линейно упорядоченный набор меток секретности;
- каждому объекту системы присвоена метка секретности, определяющая ценность содержащей в ней информации — *уровень секретности*;
- каждому субъекту системы присвоена метка секретности, определяющая уровень доступа к нему; метка секретности субъекта называется его уровнем доступа.

Основная цель мандатной политики – предотвращение утечки информации от объектов с высоким уровнем доступа к объектам низким уровнем доступа. Важное достоинство мандатной модели – формальное доказательство утверждения: *если начальное состояние системы безопасно, и все переходы системы из состояния в состояние не нарушают ограничений, сформулированных политикой безопасности, то любое состояние системы безопасно*. Недостаток мандатной модели – сложность реализации. Множество операций ограничивается операциями чтения (поток данных направлен от объекта к субъекту) и записи (поток направлен от субъекта к объекту).

Чаще всего основой реализации политики разграничения доступа к ресурсам при обработке сведений конфиденциального характера является дискреционная модель, а секретных сведений – мандатная.

п.4. Монитор безопасности и его функции.

При реализации политики безопасности на уровне доступа в информационной системе должен существовать модуль, обеспечивающий выполнение операций доступа на основе выбранной модели – монитор безопасности или диспетчер доступа.

Диспетчер доступа является центральным элементом системы защиты и идентифицирует субъекты, объекты и параметры запрашиваемого доступа субъектов к объектам. Именно монитор безопасности предоставляет запрашиваемый доступ или запрещает его.

Основными функциями монитора безопасности являются:

1. Обеспечение корректности и однозначности реализации разграничительной политики доступа к ресурсам, т.е. каждому субъекту однозначно указывается набор объектов, к которым разрешен легитимный доступ.
2. Обеспечение полноты реализации разграничительной политики доступа к ресурсам, т.е. управление доступом должно быть применено не только каждому субъекту, но и к каждому объекту.
3. Монитор безопасности должен обнаруживать как явные, так и скрытые действия субъекта при доступе к объекту, т.е. противодействовать как явным, так и скрытым угрозам.
4. Монитор безопасности должен обеспечивать реализацию всех функций администрирования (изменение учётной записи, изменение правил разграничения доступа, изменение списка субъектов). При этом диспетчер доступа должен предоставлять право изменять учетную информацию субъектов только уполномоченным субъектам (администраторы, служба безопасности).
5. Монитор безопасности должен содержать в своём составе средства управления, ограничивающие распространение прав на доступ.

Тема 6. Политика безопасности информационных систем.

п.1. Административный уровень защиты информации.

К административному уровню информационной безопасности относятся действия общего характера, предпринимаемые руководством организации к обеспечению защиты информации. Главная цель – формирование политики безопасности, отражающей подход организации к защите данных.

Политика безопасности административного уровня – совокупность документированных решений, принимаемых руководством организации и направленных на защиту информации и ассоциированных с ней ресурсов.

Выработку политики безопасности и ее содержание рассматривают на трех горизонтальных уровнях детализации:

- Верхний уровень – вопросы, относящийся к организации в целом;
- Средний уровень – вопросы, касающиеся отдельных аспектов информационной безопасности;
- Нижний уровень – вопросы относящиеся к конкретным сервисам.

После формулирования политики безопасности, составляется программа обеспечения информационной безопасности. Программа безопасности также структурируется по уровням. В простом случае достаточно двух уровней:

- верхнего (центрального) – охватывающего всю организацию;
- нижнего (служебного) – относящегося к отдельным услугам или группам однородных сервисов.

п.2. Разработка и реализация политики безопасности.

Разработка политики информационной безопасности в общем случае является итерационным процедурой, состоящей из выполнения следующих шагов:

Первый шаг – разработка гипотетически идеальной для предприятия политики, куда закладываются те требования, которые идеально подходят для данного предприятия – формулируются некий идеальный профиль защиты.

Второй шаг – выбор (либо разработка) системы защиты, максимально обеспечивающей выполнение требований гипотетически идеальной политики информационной безопасности.

Третий шаг – определение требований политики информационной безопасности, которые не выполняются системой защиты.

Политика безопасности верхнего уровня, затрагивающая все организацию в целом, включает в себя:

- а. решение сформировать или изменить комплексную программу обеспечения информационной безопасности;
- б. формулирование целей организации в области информационной безопасности, определение общих направлений в достижении данных целей;
- в. обеспечение нормативной базы для соблюдения законов и правил;
- г. формулирование административных решений по вопросам, затрагивающих организацию в целом.

На данном уровне решаются следующие вопросы:

- а. управление ресурсами защиты и координация использования данных ресурсов;
- б. выделение персонала для защиты критически важных систем;
- в. определение взаимодействия с внешними организациями, обеспечивающими или контролирующими режим безопасности;
- г. определение правил соблюдения законодательных и нормативных правил, контроля за действия сотрудников, выработка системы поощрений и наказаний.

К среднему уровню относят вопросы, относящиеся к отдельным аспектам информационной безопасности. Например, организация доступа сотрудников в сеть Интернет или установка и использование ПО.

Средний уровень политики безопасности определяет решение вопросов, касающихся отдельных аспектов информационной безопасности, но важных для различных систем, эксплуатируемых организацией.

Примеры таких вопросов - отношение к доступу в Интернет (проблема сочетания свободы получения информации с защитой от внешних угроз), использование домашних компьютеров и т.д.

Политика безопасности среднего уровня должна определять для каждого аспекта информационной безопасности следующие моменты:

- описание аспекта - позиция организации может быть сформулирована в достаточно общем виде как набор целей, которые преследует организация в данном аспекте;
- область применения - следует специфицировать, где, когда, как, по отношению к кому и чему применяется данная политика безопасности;

- роли и обязанности - документ должен содержать информацию о должностных лицах, отвечающих за проведение политики безопасности в жизнь;
- санкции - политика должна содержать общее описание запрещенных действий и наказаний за них;
- точки контакта - должно быть известно, куда следует обращаться за разъяснениями, помощью и дополнительной информацией. Обычно «точкой контакта» служит должностное лицо.

Политика среднего уровня для каждого аспекта должна освещать: описание аспекта; область применения; позицию организации по данному вопросу; роли и обязанности персонала; точки контакта различных подразделений.

Политика безопасности нижнего уровня относится к работе конкретных информационных сервисов. Нижний уровень политики безопасности относится к конкретным сервисам. Эта политика включает в себя два аспекта: цели и правила их достижения, — поэтому ее порой трудно отделить от вопросов реализации. В отличие от двух верхних уровней, рассматриваемая политика должна быть более детальной.

Приведем несколько примеров вопросов, на которые следует дать ответ при следовании политике безопасности нижнего уровня:

- кто имеет право доступа к объектам, поддерживаемым сервисом;
- при каких условиях можно читать и модифицировать данные;
- как организован удаленный доступ к сервису.

Политика безопасности нижнего уровня может исходить из соображений целостности, доступности и конфиденциальности, но она не должна на них останавливаться. В общем случае цели должны связывать между собой объекты сервиса и осмысленные действия с ними.

Из целей выводятся правила безопасности, описывающие, кто, что и при каких условиях может делать. Чем детальнее правила, чем более четко и формально они изложены, тем проще поддержать их выполнение программно-техническими мерами. Обычно наиболее формально задаются права доступа к объектам

п.3. Таксономия нарушений информационной безопасности вычислительной системы и причины, обуславливающие их существование.

На сегодняшний день существует достаточно большая статистика угроз операционным системам, направленных на преодоление встроенных в операционные системы механизмов защиты (изменение настроек механизмов безопасности, обход разграничения доступа). Статистика фактов несанкционированного доступа к информации показывает, что большинство распространённых систем универсального назначения довольно уязвимы с точки зрения безопасности.

Для ОС Windows характерны следующие недостатки, приводящие к нарушению информационной безопасности:

а. невозможна в общем случае реализация централизованной схемы администрирования;

- б. не в полном объёме реализуется дискреционная модель доступа;
- в. невозможно в общем случае обеспечить замкнутость (или целостность) программной среды;
- г. невозможно встроенными средствами гарантированно удалять остаточную информацию;
- д. ОС семейства Windows не обладают в полном объёме возможностью контроля целостности файловой системы;
- е. не обеспечивается регистрация выдачи документов на "твёрдую копию", а также некоторые другие требования к регистрации событий;
- ж. механизм управления доступа к хостам в полном объёме не реализуется.

Для ОС Unix характерны следующие недостатки, приводящие к нарушению информационной безопасности:

- а. невозможно обеспечить замкнутость (или целостность) программной среды;
- б. не в полном объёме реализуется дискреционная модель доступа;
- в. невозможно встроенными средствами гарантированно удалять остаточную информацию;
- г. не обладает возможностью контроля целостности файловой системы;
- д. не обеспечивается регистрация выдачи документов на "твёрдую копию", а также некоторые другие требования к регистрации событий;
- е. встроенными средствами защиты некоторых ОС семейства UNIX управление доступом к хостам не реализуется.

ОС Novell изначально задумывалась как защищённая (не универсального назначения), основной её функцией была реализация защищённого файлового сервиса. Однако с пятой версии данная ОС стала приобретать свойства универсальности, что негативно сказалось на уровне защищённости.

Таким образом, большинство современных универсальных ОС не удовлетворяют требованиям нормативных документов и не могут применяться даже для защиты конфиденциальной информации.

п.4. Анализ способов нарушения безопасности.

Анализируя все методы, позволяющие несанкционированно вмешаться в работу информационной системы, их можно разделить на несколько категорий, которые реализуются под разными операционными системами в различных соотношениях. Следующая таблица показывает процентное соотношение успешных типов атак в каждой категории от их общего числа для различных семейства операционных систем:

	Методы несанкционированного доступа	Windows	UNIX
.	Позволяющие несанкционированно запустить исполняемый код.	6%	3 9%
.	Позволяющие осуществить несанкционированные операции чтения/записи файловых и других объектов.	32 %	2 %
	Позволяющие обойти установленные разграни-	4%	4

.	чения прав доступа.		%
.	Приводящие к отказу в обслуживании (DoS-атаки)	27 %	2 4%
.	Использующие встроенные недокументированные возможности (ошибки и закладки).	5%	3 %
.	Использующие недостатки системы хранения или выбора пароля и позволяющие путём реверсирования, подбора или полного перебора получить его.	9%	7 %
.	Троянские программы	12 %	8 %
.	Прочие.	5%	1 3%

Из анализа существующей статистики угроз можно сделать следующие **выводы:**

1. Большинство угрозы в вышеперечисленных группах, напрямую используют различные недостатки ОС и системных приложений. Их реализация позволяет при полностью сконфигурированных и работающих встроенных в ОС механизмах защиты осуществлять несанкционированный доступ, что подтверждает необходимость усиления встроенных механизмов защиты.

2. Анализ известных угроз современным универсальным ОС полностью подтверждает, что большая их часть обусловлена именно реализуемым в ОС концептуальным подходом, состоящим в реализации схемы распределённого администрирования механизмов защиты.

Тема 7. Организационно-правовые методы информационной безопасности.

п.1. Основные нормативные руководящие документы, касающиеся государственной тайны, нормативно-справочные документы.

На сегодняшний день существует большое количество различных документов, регламентирующих вопросы информационной безопасности. В общем случае они могут быть сгруппированы в следующие категории (рис.):



- федеральные правовые документы, которые включают в себя кодексы и законы, указы и распоряжения Президента РФ, а также постановления Правительства РФ;
- отраслевые нормативные документы, включающие в себя российские и международные стандарты, а также специальные требования Федеральной службы по техническому и экспортному контролю (ФСТЭК) и ФСБ, касающиеся вопросов защиты информации;
- локальные организационно-распорядительные документы, которые действуют в рамках отдельно взятой организации, например, должностные инструкции, приказы, распоряжения и другие документы, касающиеся вопросов информационной безопасности.

Требования российского законодательства, определяющие обязательность защиты информации ограниченного доступа, изложены в Федеральных законах и уточнены в документах Федеральной службы по техническому и экспортному контролю Российской Федерации (Гостехкомиссии России), ФСБ (ФАПСИ) и других государственных учреждений, имеющих отношение к обеспечению безопасности информации. Реализация и контроль этих требований осуществляется при помощи соответствующих государственных систем сертификации средств защиты и аттестации объектов автоматизации.

Правовую основу информационной безопасности обеспечивают: Конституция Российской Федерации, Гражданский и Уголовный Кодекс, Федеральные законы "О безопасности" (№ 15-ФЗ от 07.03.2005), "О Государственной тайне" (№ 122-ФЗ от 22.08.2004), "Об информации, информатизации и защите информации" (№ 149-ФЗ от 27.07.2006), "Об участии в международном информационном обмене" (№ 85-ФЗ от 04.07.1996), "О коммерческой тайне" (№98-ФЗ от 29.07.2004), "О персональных данных" (№ 152-ФЗ от 27.07.2006), "О техническом регулировании" (№ 45-ФЗ от 09.05.2005), Доктрина информационной безопасности, Указы Президента и другие нормативные правовые акты Российской Федерации.

Соблюдение правовых норм, установленных законодательными актами Российской Федерации, должно являться одним из основополагающих принципов при создании любой комплексной системы защиты от информационных атак.

Общие правовые основы обеспечения безопасности личности, общества и государства определены в Федеральном законе "О безопасности". Этим же законом

определено понятие системы безопасности и ее функций, установлен порядок организации и финансирования органов обеспечения безопасности и правила контроля и надзора за законностью их деятельности.

Выделяют 4 уровня правового обеспечения информационной безопасности.

Первый уровень образуют международные договоры, к которым присоединилась Российская Федерация, и федеральные законы России:

международные (всемирные) конвенции об охране промышленной собственности, охране интеллектуальной собственности, авторском праве;

В соответствии с Конституцией Российской Федерации (ст. 23, 24) мероприятия по защите данных от возможных информационных атак не должны нарушать тайну переписки, осуществлять сбор сведений о частной жизни сотрудников, а также ознакомление с их перепиской.

нарушение тайны переписки, телефонных переговоров и телеграфных сообщений граждан является уголовным преступлением и наказывается исправительными работами на срок до шести месяцев или штрафом до одного минимального месячного размера оплаты труда.

В Гражданском кодексе Российской Федерации (ст. 139) определены характерные признаки информации, которая может составлять служебную или коммерческую тайну. Кроме этого в гражданском кодексе установлена ответственность, которую несут лица, за незаконные методы получения такой информации. (ст. 139, возмещение убытков от утечек);

Уголовным Кодексом Российской Федерации предусматривается ответственность в случае преднамеренного использования вредоносного программного обеспечения с целью:

сбора или распространения сведений о частной жизни лица, составляющих его личную или семейную тайну, без его согласия (ст. 137);

наказываются штрафом в размере до двухсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати месяцев, либо обязательными работами на срок до трехсот шестидесяти часов, либо исправительными работами на срок до одного года, либо принудительными работами на срок до двух лет с лишением права занимать определенные должности или заниматься определенной деятельностью на срок до трех лет или без такового, либо арестом на срок до четырех месяцев, либо лишением свободы на срок до двух лет с лишением права занимать определенные должности или заниматься определенной деятельностью на срок до трех лет.

нарушения тайны переписки, телефонных переговоров, почтовых, телеграфных или иных сообщений, с использованием специальных технических средств, предназначенных для негласного получения информации (ст. 138).

наказывается штрафом в размере до восьмидесяти тысяч рублей или в размере заработной платы или иного дохода осужденного за период до шести месяцев, либо обязательными работами на срок до трехсот шестидесяти часов, либо исправительными работами на срок до одного года.

незаконного получения или разглашения сведений, составляющих коммерческую или банковскую тайну (ст. 183);

наказываются штрафом в размере до одного миллиона рублей или в размере заработной платы или иного дохода осужденного за период до двух лет с лишением права занимать определенные должности или заниматься опреде-

ленной деятельностью на срок до трех лет, либо исправительными работами на срок до двух лет, либо принудительными работами на срок до трех лет, либо лишением свободы на тот же срок.

неправомерного доступа к охраняемой законом компьютерной информации (ст. 272);

наказывается штрафом в размере от ста тысяч до трехсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период от одного года до двух лет, либо исправительными работами на срок от одного года до двух лет, либо ограничением свободы на срок до четырех лет, либо принудительными работами на срок до четырех лет, либо лишением свободы на тот же срок.

Уголовная ответственность распространяется также на лиц, совершивших действия по созданию, использованию и распространению вредоносных программ для ЭВМ (ст. 273).

наказываются ограничением свободы на срок до четырех лет, либо принудительными работами на срок до четырех лет, либо лишением свободы на тот же срок со штрафом в размере до двухсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати месяцев.

При этом необходимо отметить, что в качестве вредоносного ПО могут выступать не только вирусы, программы типа "Троянский конь", но и программы, предназначенные для проведения информационных атак.

нарушения правил эксплуатации ЭВМ, системы ЭВМ или их сети, повлекшее уничтожение, блокирование или модификацию охраняемой законом информации ЭВМ (ст. 274);

наказывается штрафом в размере до пятисот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати месяцев, либо исправительными работами на срок от шести месяцев до одного года, либо ограничением свободы на срок до двух лет, либо принудительными работами на срок до двух лет, либо лишением свободы на тот же срок.

Регулирование отношений, связанных с созданием, правовой охраной, а также использованием программ для ЭВМ и баз данных, осуществляется при помощи законов "О правовой охране программ для электронных вычислительных машин и баз данных" и "Об авторском праве и смежных правах".

Федеральный закон "Об участии в международном информационном обмене" также определяет понятие информационной безопасности и направлен на создание условий для эффективного участия России в международном информационном обмене в рамках единого мирового информационного пространства. Требования данного нормативного документа необходимо учитывать при взаимодействии с зарубежными информационными ресурсами, например, через сеть Интернет. Отношения, возникающие при формировании и использовании информационных ресурсов на основе создания, сбора, обработки, накопления и предоставления потребителю документированной информации, регулируются Федеральным законом "Об информации, информатизации и защите информации". Данный закон определяет понятие конфиденциальной информации, цели и задачи по ее защите, а также права и обязанности субъектов в области защиты информации. В 2006 г. эти два закона были заменены Федеральным законом "Об информации, информационных технологиях и о защите информации", в соответствии с которым защита

информации представляет собой принятие правовых, организационных и технических мер, направленных на:

- обеспечение защиты информации от неправомерного доступа, уничтожения, модифицирования, блокирования, копирования, предоставления, распространения, а также от иных неправомерных действий в отношении такой информации;
- соблюдение конфиденциальности информации ограниченного доступа;
- реализацию права на доступ к информации.

Второй уровень составляют подзаконные акты, к которым относятся указы Президента РФ, постановления Правительства РФ, письма Высшего Арбитражного Суда РФ, постановления пленумов Верховного Суда РФ.

Третий уровень составляют государственные стандарты (ГОСТы) в области защиты информации (ГОСТ Р 50922-96 "Защита информации. Основные термины и определения", ГОСТ Р 50739-95 "Средства вычислительной техники. Защита от несанкционированного доступа к информации. Общие технические требования", ГОСТ 28147-89 "Системы обработки информации. Защита криптографическая. Алгоритм криптографического преобразования"), руководящие документы (руководящие документы Государственной технической комиссии при Президенте РФ), нормы, методики и классификаторы, разработанные соответствующими органами.

Четвёртый уровень образуют локальные нормативные акты, положения, инструкции, методические рекомендации и другие документы по комплексной защите информации в информационных системах конкретной организации (список сведений, составляющих коммерческую тайну предприятия и т.п.).

п.2. Место информационной безопасности экономических систем в национальной безопасности страны.

Обеспечение информационной безопасности осуществляется в рамках обеспечения национальной безопасности России. Оно предусматривает наличие государственной системы защиты информации и законодательства в этой области.

Под национальной безопасностью следует понимать состояние защищенности жизненно важных национальных интересов от внутренних и внешних угроз. Система национальных интересов России определяется совокупностью основных интересов личности, общества, государства и охватывает все сферы их деятельности, поэтому в содержании понятия "национальная безопасность" можно выделить различные структурные элементы (компоненты), к основным из которых относятся политическая, экономическая, военная, экологическая и информационная безопасность.

Информационная безопасность – состояние защищенности информационных ресурсов от внутренних и внешних угроз, способных нанести ущерб интересам личности, общества, государства (национальным интересам).

Поскольку в условиях информатизации страны, развития информационных технологий, информационные ресурсы формируются во всех сферах дея-

тельности, и в первую очередь в политической, военной, экономической, научно-технической, информационную безопасность следует рассматривать как комплексный показатель национальной безопасности. Этим определяется ее важное место и одна из ведущих ролей в системе национальной безопасности страны в современных условиях.

На основе анализа угроз национальной безопасности, сделан вывод о том, что главные из них в настоящее время и в обозримой перспективе не имеют военной направленности, носят преимущественно внутренний характер и содержатся во внутривнутриполитической, экономической, социальной, экологической и информационной безопасности.

Основными принципами обеспечения безопасности являются:

- законность;
- соблюдение баланса жизненно важных интересов личности, общества и государства;
- взаимная ответственность личности, общества и государства по обеспечению безопасности;
- интеграция с международными системами безопасности.

Систему национальной безопасности образуют:

- органы законодательной, исполнительной и судебной властей;
- государственные, общественные и иные организации и объединения;
- граждане, принимающие участие в обеспечении безопасности в соответствии с законом;
- законодательство, регламентирующее отношения в сфере безопасности.

п.3. Концепция информационной безопасности.

"Доктрина информационной безопасности Российской Федерации" (утверждена Президентом РФ 09.09.2000 г. Пр-1895) представляет собой совокупность официальных взглядов на цели, задачи, принципы и основные направления обеспечения информационной безопасности РФ и развивает "Концепцию национальной безопасности Российской Федерации" применительно к информационной сфере.

Выделены *четыре основные* составляющие национальных интересов РФ в информационной сфере:

1. Обеспечение конституционных прав и свобод человека и гражданина на личную и семейную тайны, тайну переписки, телефонных переговоров, почтовых, телеграфных и иных сообщений, на защиту своей чести и своего доброго имени.

2. Разработка и укрепление механизмов правового регулирования отношений в области охраны интеллектуальной собственности, создание условий для соблюдения установленных федеральным законодательством ограничений на доступ к конфиденциальной информации.

3. Обеспечение запрета на сбор, хранение, использование и распространение информации о частной жизни лица без его согласия и другой информации, доступ к которой ограничен федеральным законодательством.

4. Защита информационных ресурсов от несанкционированного доступа, обеспечение безопасности информационных и телекоммуникационных систем, как уже развернутых, так и создаваемых на территории России, обеспече-

ние защиты сведений, составляющих государственную тайну, противодействие угрозе развязывания противоборства в информационной сфере.

п.4. Назначение и задачи в сфере обеспечения информационной безопасности на уровне государства.

Анализ состояния информационной безопасности Российской Федерации показывает, что ее уровень не в полной мере соответствует потребностям общества и государства. На лицо обострение противоречий между потребностью общества и государства в расширении свободного обмена информацией и необходимостью сохранения отдельных регламентированных ограничений на ее распространение. Неудовлетворительно организована защита собираемых органами государственной власти и местного самоуправления данных о физических лицах (персональные данные). С каждым годом ухудшается ситуация с обеспечением сохранности сведений, составляющих государственную тайну. Существенно возрастает угроза применения "информационного оружия" против информационной инфраструктуры России.

Основные задачи по обеспечению информационной безопасности РФ:

1. разработка федеральных целевых программ обеспечения информационной безопасности Российской Федерации, в том числе противодействия деятельности иностранных разведок и негативного информационного давления внешних источников;
2. разработка современных методов и средств защиты информации, обеспечения безопасности информационных технологий;
3. повышение степени защищенности законных интересов граждан, общества и государства в информационной сфере, в том числе правовыми и административными методами.
4. усиления контроля за развитием информационного рынка России, в том числе за соблюдением авторских и смежных прав.

К правовым методам обеспечения информационной безопасности относят:

1. определение целей, задач и механизмов участия в этой деятельности общественных объединений, организаций и граждан;
2. определение ответственности физических и юридических лиц за несанкционированный доступ к информации;
3. определение ответственности физических и юридических лиц за противоправное раскрытие конфиденциальной информации, использование в преступных и корыстных целях служебной информации или информации, содержащей коммерческую тайну.

Тема 8. Основные понятия криптографии.

п.1. История развития криптографии

Проблема защиты информации путем ее преобразования, исключаящего ее прочтение посторонним лицом, волновала человеческий ум с давних времен. История криптографии - ровесница истории человеческого языка. Более того, первоначально письменность сама по себе была криптографической сис-

темой, так как в древних обществах ею владели только избранные. Священные книги Древнего Египта, Древней Индии тому примеры.

С широким распространением письменности криптография стала формироваться как самостоятельная наука. Первые криптосистемы встречаются уже в начале нашей эры. Так, Цезарь в своей переписке использовал уже более менее систематический шифр, получивший его имя.

Бурное развитие криптографические системы получили в годы первой и второй мировых войн. Начиная с послевоенного времени и по нынешний день появление вычислительных средств ускорило разработку и совершенствование криптографических методов.

История криптографии насчитывает около 4 тысяч лет. В качестве основного критерия периодизации криптографии возможно использовать технологические характеристики используемых методов шифрования.

Первый период (приблизительно с 3-го тысячелетия до н. э.) характеризуется господством моноалфавитных шифров (основной принцип — замена алфавита исходного текста другим алфавитом через замену букв другими буквами или символами).

Второй период (хронологические рамки — с IX века на Ближнем Востоке (Ал-Кинди) и с XV века в Европе (Леон Баттиста Альберти) — до начала XX века) ознаменовался введением в обиход полиалфавитных шифров.

Третий период (с начала и до середины XX века) характеризуется внедрением электромеханических устройств в работу шифровальщиков. При этом продолжалось использование полиалфавитных шифров.

Четвёртый период — с середины до 70-х годов XX века — период перехода к математической криптографии. В работе Шеннона появляются строгие математические определения количества информации, передачи данных, энтропии, функций шифрования. Обязательным этапом создания шифра считается изучение его уязвимости к различным известным атакам — линейному и дифференциальному криптоанализу. Однако до 1975 года криптография оставалась «классической» или же, более корректно, криптографией с секретным ключом.

Современный период развития криптографии (с конца 1970-х годов по настоящее время) отличается зарождением и развитием нового направления — криптография с открытым ключом. Её появление знаменуется не только новыми техническими возможностями, но и сравнительно широким распространением криптографии для использования частными лицами. Правовое регулирование использования криптографии частными лицами в разных странах сильно различается — от разрешения до полного запрета.

п.2. Определение базовых понятий.

Термин шифр (cipher) происходит от арабского слова "цифра".

Криптография (cryptography) дословно переводится как "тайнопись" (от греч. kryptos – тайный и grapho – пишу) – раздел математики, занимающийся составлением алгоритмов шифрования информации. Исследование криптографических алгоритмов с целью оценки их стойкости и поиска слабых мест называется криптоанализом (cryptanalysis). Криптография и криптоанализ являются двумя составляющими науки – криптологии (cryptology).

Исходное, незашифрованное сообщение называется открытым текстом (plain text). Зашифрованное сообщение называется шифртекстом (ciphertext).

Процесс преобразования открытого текста в шифртекст называется зашифровыванием (enciphering), а обратный процесс – расшифрованием (deciphering). Термин шифрование (без приставок) в русскоязычной литературе обозначает и прямой, и обратный процесс.

Шифрование выполняется в соответствии с криптографическим алгоритмом (cryptographic algorithm). Как правило, криптографический алгоритм содержит сменный элемент – криптографический ключ (cryptographic key), позволяющий выбрать одно конкретное преобразование из множества преобразований, реализуемых данным алгоритмом.

Получение открытого текста из шифртекста без знания правильного ключа и (или) всех деталей алгоритма является основной задачей криптоанализа и называется дешифрованием. Попытка криптоанализа называется атакой.

Раскрытие ключа шифрования без привлечения методов криптоанализа называется компрометацией.

п.3. Задачи и методы криптографии.

1. Секретность. Должна быть обеспечена защита конфиденциальной информации при хранении её на открытых носителях, при передаче по открытым каналам связи. Злоумышленник не должен получить доступ к информации, не предназначенной для него. Реализуется с помощью алгоритмов шифрования или криптосистем.

2. Аутентификация. Получатель сообщения в состоянии проверить, что оно исходит от конкретного отправителя. Злоумышленник не может прислать фальшивое сообщение от чьего-либо имени. Реализуется с помощью использования паролей и специальных хэш-функций.

3. Целостность. Получатель сообщения в состоянии проверить, были ли внесены какие-нибудь изменения в полученное сообщение в ходе его передачи. Злоумышленнику не позволено заменить настоящее сообщение на фальшивое. Реализуется с помощью проверки хэш-функций от текста сообщения.

4. Неоспоримость. Отправитель сообщения должен быть лишён возможности впоследствии отрицать, что именно он является автором этого сообщения. Реализуется с помощью электронной цифровой подписи и операции датирования.

Тема 9. Алгоритмы шифрования.

п.1. Общая характеристика шифров.

Любой алгоритм шифрования, называемый также шифром, представляет собой две связанные математические функции, используемые для прямого и обратного преобразования информации. В некоторых алгоритмах эти функции идентичны.

Существуют два основных типа криптографических алгоритмов: симметричные, для которых ключ расшифрования совпадает с ключом зашифрования или может быть легко из него получен, и асимметричные,

использующие для зашифрования и расшифрования два разных ключа. Асимметрические алгоритмы также называются алгоритмами с открытым ключом.

Симметричные алгоритмы делятся на две категории. К первой категории относятся алгоритмы, которые обрабатывают шифруемые данные побитово или посимвольно. Такие алгоритмы называют потоковыми шифрами. Ко второй категории относятся алгоритмы, производящие операции над группами битов. Такие группы битов называют блоками, а алгоритмы – блочными шифрами.

В современных шифрах применяется принцип Керкхоффа, согласно которому в криптосистеме используется сменный элемент, называемый ключом, и секретность шифра обеспечивается секретностью ключа шифрования.

Хороший алгоритм шифрования имеет следующие статистические характеристики:

1. отсутствие статистической зависимости между открытым текстом и шифртекстом;
2. шифртекст по статистическим характеристикам не отличим от истинно случайной последовательности;
3. изменение любого бита в ключе шифрования при неизменном открытом тексте приводит к изменению примерно 50% бит шифртекста (для симметричных алгоритмов);
4. изменение любого бита в блоке открытого текста при неизменном ключе шифрования приводит к изменению примерно 50% бит шифртекста (для блочных алгоритмов).

Преимущества симметричных алгоритмов: скорость выполнения криптографических преобразований и относительная легкость внесения изменений в алгоритм шифрования.

Недостаток симметричного шифрования: известен получателю и отправителю, что создает проблемы при распространении ключей и доказательстве подлинности сообщения

Преимущества несимметричных алгоритмов: секретный ключ известен только получателю информации и первоначальный обмен не требует передачи секретного ключа; применим в системах аутентификации (электронная цифровая подпись).

Недостаток асимметричного шифрования: низкое быстродействие алгоритмов (из-за длины ключа и сложности преобразований).

п.2. Алгоритм обмена ключами.

Протокол Диффи-Хеллмана (англ. Diffie-Hellman, DH) — криптографический протокол, позволяющий двум и более сторонам получить общий секретный ключ, используя незащищенный от прослушивания канал связи. Полученный ключ используется для шифрования дальнейшего обмена с помощью алгоритмов симметричного шифрования.

Схема открытого распределения ключей, предложенная Диффи и Хеллманом, произвела настоящую революцию в мире шифрования, так как

сняла основную проблему классической криптографии — проблему распределения ключей.

Передача ключа по открытым каналам была большой проблемой криптографии XX века. Но эту проблему удалось решить после появления алгоритма Диффи-Хеллмана. Данный алгоритм позволил дать ответ на главный вопрос:

«Как при обмене зашифрованными посланиями уйти от необходимости передачи секретного кода расшифровки, который, как правило, не меньше самого послания?» Открытое распространение ключей Диффи-Хеллмана позволяет паре пользователей системы выработать общий секретный ключ, не обмениваясь секретными данными.

Первая публикация данного алгоритма появилась в 70-х годах XX века в статье Диффи и Хеллмана, в которой вводились основные понятия криптографии с открытым ключом. *Алгоритм Диффи-Хеллмана* не применяется для шифрования сообщений или формирования электронной подписи. Его назначение – в распределении ключей. Он позволяет двум или более пользователям обмениваться без посредников ключом, который может быть использован затем для симметричного шифрования. Это была первая криптосистема, которая позволяла защищать информацию без использования секретных ключей, передаваемых по защищенным каналам. Схема открытого распределения ключей, предложенная Диффи и Хеллманом, произвела настоящую революцию в мире шифрования, так как снимала основную проблему классической криптографии – проблему распределения ключей.

Алгоритм основан на трудности вычислений *дискретных логарифмов*. Попробуем разобраться, что это такое. В этом алгоритме, как и во многих других алгоритмах с открытым ключом, вычисления производятся по модулю некоторого большого простого числа P . Вначале специальным образом подбирается некоторое натуральное число A , меньшее P . Если мы хотим зашифровать значение X , то вычисляем

$$Y = A^X \bmod P.$$

Причем, имея X , вычислить Y легко. Обратная задача вычисления X из Y является достаточно сложной. Экспонента X как раз и называется *дискретным логарифмом* Y . Таким образом, зная о сложности вычисления *дискретного логарифма*, число Y можно открыто передавать по любому каналу связи, так как при большом модуле P исходное значение X подобрать будет практически невозможно. На этом математическом факте основан *алгоритм Диффи-Хеллмана* для формирования ключа.

Формирование общего ключа

Пусть два пользователя, которых условно назовем пользователь 1 и пользователь 2, желают сформировать общий ключ для алгоритма симметричного шифрования. Вначале они должны выбрать большое простое число P и некоторое специальное число A , $1 < A < P-1$, такое, что все числа из интервала $[1, 2, \dots, P-1]$ могут быть представлены как различные степени $A \bmod P$. Эти числа должны быть известны всем абонентам системы и могут выбираться открыто. Это будут так называемые *общие параметры*.

Затем первый пользователь выбирает число X_1 ($X_1 < P$), которое желательно формировать с помощью датчика случайных чисел. Это будет закрытый

ключ первого пользователя, и он должен держаться в секрете. На основе закрытого ключа пользователь 1 вычисляет число

$$Y_1 = A^{X_1} \bmod P$$

которое он посылает второму абоненту.

Аналогично поступает и второй пользователь, генерируя X_2 и вычисляя

$$Y_2 = A^{X_2} \bmod P$$

Это значение пользователь 2 отправляет первому пользователю.

После этого у пользователей должна быть информация, указанная в следующей таблице:

общий секретный ключ Z для сеанса симметричного шифрования. Вот как это должен сделать первый пользователь:

$$Z = (Y_2)^{X_1} \bmod P$$

Никто другой кроме пользователя 1 этого сделать не может, так как число X_1 секретно. Второй пользователь может получить то же самое число Z , используя свой закрытый ключ и открытый ключ своего абонента следующим образом:

$$Z = (Y_1)^{X_2} \bmod P$$

Если весь протокол формирования общего секретного ключа выполнен верно, значения Z у одного и второго абонента должны получиться одинаковыми. Причем, что самое важное, противник, не зная секретных чисел X_1 и X_2 , не сможет вычислить число Z . Не зная X_1 и X_2 , злоумышленник может попытаться вычислить Z , используя только передаваемые открыто P , A , Y_1 и Y_2 . Безопасность формирования общего ключа в алгоритме Диффи-Хеллмана вытекает из того факта, что, хотя относительно легко вычислить экспоненты по модулю простого числа, очень трудно вычислить дискретные логарифмы. Для больших простых чисел размером сотни и тысячи бит задача считается неразрешимой, так как требует колоссальных затрат вычислительных ресурсов.

Пользователи 1 и 2 могут использовать значение Z в качестве секретного ключа для шифрования и расшифрования данных. Таким же образом любая пара абонентов может вычислить секретный ключ, известный только им.

п.3. Симметричные алгоритмы.

Симметричные криптосистемы (также симметричное шифрование, симметричные шифры) — способ шифрования, в котором для шифрования и расшифровывания применяется один и тот же криптографический ключ. До изобретения схемы асимметричного шифрования единственным существовавшим способом являлось симметричное шифрование. Ключ алгоритма должен сохраняться в секрете обеими сторонами. Алгоритм шифрования выбирается сторонами до начала обмена сообщениями.

Рассмотрим общую схему симметричной, или традиционной, криптографии.



Рис. Общая схема симметричного шифрования

В процессе шифрования используется определенный алгоритм шифрования, на вход которому подаются исходное незашифрованное сообщение, называемое также plaintext, и ключ. Выходом алгоритма является зашифрованное сообщение, называемое также ciphertext. Ключ является значением, не зависящим от шифруемого сообщения. Изменение ключа должно приводить к изменению зашифрованного сообщения.

Зашифрованное сообщение передается получателю. Получатель преобразует зашифрованное сообщение в исходное незашифрованное сообщение с помощью алгоритма дешифрования и того же самого ключа, который использовался при шифровании, или ключа, легко получаемого из ключа шифрования.

Незашифрованное сообщение будем обозначать P или M , от слов plaintext и message. Зашифрованное сообщение будем обозначать C , от слова ciphertext.

Характерная особенность симметричных блочных алгоритмов заключается в том, что в ходе своей работы они производят преобразование блока входной информации фиксированной длины и получают результирующий блок того же объема, но не доступный для прочтения сторонним лицам, не владеющим ключом. Таким образом, схему работы симметричного блочного шифра можно описать функциями:

Функция.

$$C = EK(M),$$

$$M = DK(C),$$

где M – исходный (открытый) блок данных;

C – зашифрованный блок данных.

Ключ K является параметром симметричного блочного криптоалгоритма и представляет собой блок двоичной информации фиксированного размера. Исходный M и зашифрованный C блоки данных также имеют равную фиксированную разрядность (но не обязательно равную длине ключа K).

ГОСТ 28147-89 - отечественный стандарт на шифрование данных. Стандарт включает три алгоритма зашифровывания (расшифровывания) данных: режим простой замены, режим гаммирования, режим гаммирования с обратной связью - и режим выработки имитовставки.

С помощью имитовставки можно зафиксировать случайную или умышленную модификацию зашифрованной информации. Вырабатывать имитовставку можно или перед зашифровыванием (после расшифровывания) всего сообщения, или одновременно с зашифровыванием (расшифровыванием) по блокам. При этом блок информации шифруется

первыми шестнадцатью циклами в режиме простой замены, затем складывается по модулю 2 со вторым блоком, результат суммирования вновь шифруется первыми шестнадцатью циклами и т. д.

Алгоритмы шифрования ГОСТ 28147-89 обладают достоинствами других алгоритмов для симметричных систем и превосходят их своими возможностями. Так, ГОСТ 28147-89 (256-битовый ключ, 32 цикла шифрования) по сравнению с такими алгоритмами, как DES (56-битовый ключ, 16 циклов шифрования) и FEAL-1 (64-битовый ключ, 4 цикла шифрования) обладает более высокой криптостойкостью за счет более длинного ключа и большего числа циклов шифрования.

Следует отметить, что в отличие от DES, у ГОСТ 28147-89 блок подстановки можно произвольно изменять, то есть он является дополнительным 512-битовым ключом.

DES (англ. data encryption standard) — алгоритм для симметричного шифрования, разработанный фирмой IBM и утверждённый правительством США в 1977 году как официальный стандарт (FIPS 46-3). Размер блока для DES равен 64 бита. В основе алгоритма лежит сеть Фейстеля с 16 циклами (раундами) и ключом, имеющим длину 56 бит. Алгоритм использует комбинацию нелинейных (S-блоки) и линейных (перестановки E, IP, IP-1) преобразований. Для DES рекомендовано несколько режимов.

п.4. Асимметричные алгоритмы.

Асимметричные алгоритмы шифрования называются также алгоритмами с открытым ключом. В отличие от алгоритмов симметричного шифрования (алгоритмов шифрования с закрытым ключом), в которых для шифрования и расшифрования используется один и тот же ключ, в асимметричных алгоритмах один ключ используется для шифрования, а другой, отличный от первого, — для расшифрования. Алгоритмы называются асимметричными, так как ключи шифрования и расшифрования разные, следовательно, отсутствует симметрия основных криптографических процессов. Один из двух ключей является открытым (public key) и может быть объявлен всем, а второй — закрытым (private key) и должен держаться в секрете. Какой из ключей, открытый или закрытый, используется для шифрования, а какой для расшифрования, определяется назначением криптографической системы.

В настоящее время асимметричные алгоритмы широко применяются на практике, например, для обеспечения информационной безопасности телекоммуникационных сетей, в том числе сетей, имеющих сложную топологию; для обеспечения информационной безопасности в глобальной сети Internet; в различных банковских и платежных системах (в том числе использующих интеллектуальные карты).

Алгоритмы шифрования с открытым ключом можно использовать для решения, как минимум, трех задач:

- Для шифрования передаваемых и хранимых данных в целях их защиты от несанкционированного доступа.
- Для формирования цифровой подписи под электронными документами.
- Для распределения секретных ключей, используемых потом при шифровании документов симметричными методами.

Алгоритм шифрования с открытым ключом RSA был предложен одним из первых в конце 70-х годов XX века. Его название составлено из первых букв фамилий авторов: Р.Райвеста (R.Rivest), А.Шамира (A.Shamir) и Л.Адлемана (L.Adleman). Алгоритм RSA является, наверно, наиболее популярным и широко применяемым *асимметричным алгоритмом* в криптографических системах.

Алгоритм основан на использовании того факта, что задача разложения большого числа на простые сомножители является трудной. Криптографическая система RSA базируется на следующих двух фактах из теории чисел:

1. задача проверки числа на простоту является сравнительно легкой;
2. задача разложения чисел вида $n = pq$ (p и q — простые числа); на множители является очень трудной, если мы знаем только n , а p и q — большие числа (это так называемая задача факторизации),

Алгоритм RSA представляет собой блочный алгоритм шифрования, где зашифрованные и незашифрованные данные должны быть представлены в виде целых чисел между 0 и $n - 1$ для некоторого n .

Шифрование

Итак, рассмотрим сам алгоритм. Пусть абонент А хочет передать зашифрованное сообщение абоненту Б. В этом случае абонент Б должен подготовить пару (открытый ключ; закрытый ключ) и отправить свой открытый ключ пользователю А.

Первым этапом является генерация открытого и закрытого ключей. Для этого вначале выбираются два больших простых числа P и Q . Затем вычисляется произведение N :

$$N = PQ.$$

После этого определяется вспомогательное число f :

$$f = (P - 1)(Q - 1).$$

Затем случайным образом выбирается число $d < f$ и взаимно простое с f .

Далее необходимо найти число e , такое, что

$$ed \bmod f = 1.$$

Числа d и N будут открытым ключом пользователя, а значение e — закрытым ключом.

Таким образом, на этом этапе у пользователя должна быть информация, указанная в следующей таблице:

Б хочет получить зашифрованное сообщение от пользователя А, значит пользователь Б должен отправить свой открытый ключ (d, N) пользователю А. Числа P и Q больше не нужны, однако их нельзя никому сообщать; лучше всего их вообще забыть.

На этом этап подготовки ключей закончен и можно использовать основной протокол RSA для шифрования данных.

Второй этап – шифрование данных. Если абонент А хочет передать некоторые данные абоненту Б, он должен представить свое сообщение в цифровом виде и разбить его на блоки $m_1, m_2, m_3, \dots$, где $m_i < N$. Зашифрованное сообщение будет состоять из блоков c_i .

Абонент А шифрует каждый блок своего сообщения по формуле

$$c_i = m_i^d \bmod N$$

используя *открытые параметры* пользователя Б, и пересылает зашифро-

ванное сообщение $C=(c_1, c_2, c_3, \dots)$ по открытой линии.

Абонент Б, получивший зашифрованное сообщение, расшифровывает все блоки полученного сообщения по формуле

$$m_i = c^e \bmod N$$

Все расшифрованные блоки будут точно такими же, как и исходящие от пользователя А.

Злоумышленник, перехватывающий все сообщения и знающий всю открытую информацию, не сможет найти исходное сообщение при больших значениях P и Q .

Асимметричный алгоритм, предложенный в 1985 году Эль-Гамалем (Т. ElGamal), универсален. Он может быть использован для решения всех трех основных задач: для шифрования данных, для формирования цифровой подписи и для согласования общего ключа. Кроме того, возможны модификации алгоритма для схем проверки пароля, доказательства идентичности сообщения и другие варианты. Безопасность этого алгоритма, так же как и алгоритма Диффи-Хеллмана, основана на трудности вычисления дискретных логарифмов. Этот алгоритм фактически использует схему Диффи-Хеллмана, чтобы сформировать общий секретный ключ для абонентов, передающих друг другу сообщение, и затем сообщение шифруется путем умножения его на этот ключ.

И в случае шифрования, и в случае формирования цифровой подписи каждому пользователю необходимо сгенерировать пару ключей. Для этого, так же как и в схеме Диффи-Хеллмана, выбираются некоторое большое простое число P и число A , такие, что различные степени A представляют собой различные числа по модулю P . Числа P и A могут передаваться в открытом виде и быть общими для всех абонентов сети.

Затем каждый абонент группы выбирает свое секретное число X_i , $1 < X_i < P-1$, и вычисляет соответствующее ему открытое число $Y_i : Y_i = A^{X_i} \bmod P$. Таким образом, каждый пользователь может сгенерировать закрытый ключ X_i и открытый ключ Y_i .

Информация о необходимых параметрах системы сведена в следующую таблицу.

Шифрование

Теперь рассмотрим, каким образом производится шифрование данных. Сообщение, предназначенное для шифрования, должно быть представлено в виде одного числа или набора чисел, каждое из которых меньше P . Пусть пользователь 1 хочет передать пользователю 2 сообщение m . В этом случае последовательность действий следующая.

1. Первый пользователь выбирает случайное число k , взаимно простое с $P-1$, и вычисляет числа

$$r = A^k \bmod P, \quad e = m \times Y_2^k \bmod P$$

где Y_2 – открытый ключ пользователя 2. Число k держится в секрете.

2. Пара чисел (r, e) , являющаяся шифротекстом, передается второму пользователю.

3. Второй пользователь, получив (r, e) , для расшифрования сообщения вычисляет

$$m = e \times r^{P-1-X_2} \bmod P$$

где X_2 – закрытый ключ пользователя 2. В результате он получает исходное сообщение m .

Если злоумышленник узнает или перехватит P, A, Y_2, r, e , то он не сможет по ним раскрыть m . Это связано с тем, что противник не знает параметр k , выбранный первым пользователем для шифрования сообщения m . Вычислить каким-либо образом число k практически невозможно, так как это задача дискретного логарифмирования. Следовательно, злоумышленник не может вычислить и значение m , так как m было умножено на неизвестное ему число. Противник также не может воспроизвести действия законного получателя сообщения (второго абонента), так как ему не известен закрытый ключ X_2 (вычисление X_2 на основании Y_2 — также задача дискретного логарифмирования).

По аналогичному алгоритму может производиться и согласование ключа, используемого для симметричного шифрования больших объемов данных. Более того, алгоритм Эль-Гамала на практике целесообразно использовать именно для согласования общего *ключа сессии*, а не прямого шифрования больших сообщений. Это связано с тем, что в алгоритме используются операции возведения в степень и умножения по большому модулю. Так же как и в алгоритмах RSA и Диффи-Хеллмана, операции производятся над большими, состоящими из нескольких сотен или тысяч бит, числами. Поэтому шифрование больших сообщений производится крайне медленно.

Тема 10. Криптографические протоколы.

п.1. Понятие протокола.

Любая задача криптографии решается с использованием определённых протоколов. Протокол – это последовательность шагов, которые предпринимают две или большее количество сторон для совместного решения задачи. Протоколы удовлетворяют следующим условиям:

1. Каждый участник протокола должен быть заранее оповещён о шагах, которые ему предстоит предпринять.
2. Все участники протокола должны следовать его правилам добровольно без принуждения.
3. Необходимо, чтобы протокол допускал только однозначное толкование, а его шаги были совершенно чётко определены и не допускали возможности их неправильного понимания.
4. Протокол должен содержать описание реакции его участников на любые ситуации, возникающие в ходе реализации этого протокола, т.е. не должно существовать ситуаций, для которой не определено соответствующее действие.

Протоколы подразделяются на три больших класса:

1. Протоколы с арбитражем. Арбитр – это участник протокола, которому остальные участники полностью доверяют и выполняют все его рекомендации. Арбитр отслеживает все шаги протокола и не имеет личной заинтересованности в достижении определённых целей, преследуемых остальными участниками протокола.
2. Протоколы с судейством. Судья – это особый арбитр, к услугам которого прибегают только в особых спорных ситуациях. Если сомнений в

правильности выполнения шагов протокола нет, то к услугам судьи не прибегают.

3. Самоутверждающиеся протоколы. Не требуют присутствия арбитра или судьи, эти протоколы устроены так, что позволяют моментально распознать, кто из участников протокола мошенничает и прекратить дальнейшее выполнение шагов протокола.

п.2. Основные криптографические протоколы.

К основным криптографическим протоколам относят

1. обмен ключами;
2. аутентификацию;
3. распределение ответственности;
4. цифровую подпись.

К вспомогательным криптографическим протоколам относят:

1. Отметки о времени создания файла (сообщения);
2. подсознательный канал и неоспоримая цифровая подпись;
3. цифровые подписи по доверенности и групповые цифровые подписи;
4. предсказание бита и бросание монеты;
5. доказательство с нулевым разглашением конфиденциальной информации;
6. анонимные совместные вычисления;
7. депонирование ключей.

Распространённым приёмом в криптографии является шифрование каждого передаваемого сообщения с помощью отдельного ключа. Такой ключ называется сеансовым, так как используется на протяжении только одного сеанса связи. При этом используется следующая обобщенная схема:

а. Оба пользователя, которые планируют обмениваться сообщениями, получают ключи (постоянные) от доверенного лица (арбитра);

б. Затем генерируются сеансовые ключи и шифруются с помощью полученных постоянных ключей, после чего пересылаются друг другу участниками связи.

в. После чего переданные сеансовые ключи используются для шифрования сообщений.

Для обмена ключами используются симметричные и ассиметричные криптосистемы, блокировочные протоколы и обмен ключами с цифровой подписью.

Аутентификация применяется при регистрации и получении доступа к некоторым информационным ресурсам. Чтобы не хранить пароли на сервере или в базе данных, которые могут вскрыть, система может распознавать правильные пароли. Эта функция реализуется с помощью однонаправленной функции (хэш-функции), значение которой может быть получено при известном аргументе, но невозможно получить аргумент по известному значению. Тогда на сервере будут храниться только наборы хэшей, по которым невозможно определить исходного пользователя. При этом алгоритм усиливается технологией периодической сменяемости паролей или добавлением "соли" или "изюминок" – специально сгенерированных случайных последовательностей.

Распределение ответственности используется при передаче ценных данных на некоторое время в чужие руки, при этом секретное сообщение (пароль) разбивается на несколько нефункциональных частей и раздается нескольким лицам. Только собравшись вместе и наблюдая друг за другом они смогут получить доступ к секретной информации.

п.3. Электронная цифровая подпись.

Электронная цифровая подпись выполняет роль обычной подписи в электронных документах для подтверждения подлинности сообщений – данные присоединяются к передаваемому сообщению, подтверждая подлинность отправителя сообщения.

При разработке механизма цифровой подписи возникает три задачи:

- а. создание подписи таким образом, чтобы ее невозможно было подделать;
- б. возможность проверки того, что подпись действительно принадлежит указанному владельцу;
- в. предотвращение отказа от подписи.

Алгоритм Эль-Гамала также можно использовать для формирования цифровой подписи. Группа пользователей выбирает общие параметры P и A . Затем каждый абонент группы выбирает свое секретное число X_i , $1 < X_i < P-1$, и вычисляет соответствующее ему открытое число $Y_i : Y_i = A^{X_i} \bmod P$. Таким образом, каждый пользователь получает пару (закрытый ключ; открытый ключ) = (X_i, Y_i) . Открытые ключи пользователей могут храниться в общей базе системы распределения ключей и при необходимости предоставляться всем абонентам системы.

Сообщение, предназначенное для подписи, должно быть представлено в виде числа, меньшего модуля P . При большом размере сообщение разбивается на блоки необходимого размера. В некоторых случаях подписывается не само сообщение, а значение хеш-функции от него. В любом варианте цифровая подпись вычисляется в зависимости от некоторого числа m ($m < P$).

Пусть пользователь 1 хочет подписать свое сообщение цифровой подписью и передать его пользователю 2. В этом случае алгоритм действий следующий.

1. Первый пользователь выбирает случайное секретное число k , взаимно простое с $P-1$, и вычисляет число $a = A^k \bmod P$
2. Затем с помощью расширенного алгоритма Евклида необходимо найти значение b в следующем уравнении:

$$m = (X_1 * a + k * b) \bmod (P-1)$$

Пара чисел (a, b) будет цифровой подписью сообщения m .

3. Сообщение m вместе с подписью (a, b) отправляется пользователю 2.

4. Пользователь 2 получает сообщение m и с использованием открытого ключа первого абонента Y_1 вычисляет два числа по следующим формулам:

$$c_1 = Y_1^a \times a^b \bmod P$$
$$c_2 = A^m \bmod P$$

5. Если $c_1 = c_2$, то цифровая подпись первого пользователя верная. Для подписывания каждого нового сообщения должно каждый раз выбираться новое значение k .

Подписи, созданные с использованием алгоритма Эль-Гамала, называются *рандомизированными*, так как для одного и того же сообщения с использованием одного и того же закрытого ключа каждый раз будут создаваться разные подписи (a,b) , поскольку каждый раз будет использоваться новое значение k . Подписи, созданные с применением алгоритма RSA, называются *детерминированными*, так как для одного и того же сообщения с использованием одного и того же закрытого ключа каждый раз будет создаваться одна и та же подпись.

Пример вычисления и проверки цифровой подписи

Пусть абоненты, обменивающиеся через Интернет зашифрованными сообщениями, имеют следующие общие параметры: $P = 11$, $A = 7$.

Один из пользователей этой системы связи хочет подписать свое сообщение $m=5$ цифровой подписью, сформированной по алгоритму Эль-Гамала. Вначале он должен выбрать себе закрытый ключ, например, $X_1=3$ и сформировать открытый ключ $Y_1 = 7^3 \bmod 11 = 2$. Открытый ключ может быть передан всем заинтересованным абонентам или помещен в базу данных открытых ключей системы связи.

Затем пользователь выбирает случайное секретное число k , взаимно простое с $P-1$. Пусть $k=9$ (9 не имеет общих делителей с 10). Далее необходимо вычислить число

$$a = A^k \bmod P = 7^9 \bmod 11 = 8$$

После этого с помощью расширенного алгоритма Евклида находится значение b в уравнении:

$$m = (X_1 \times a + k \times b) \bmod (P-1), 5 = (3 \times 8 + 9 \times b) \bmod 10$$

Решением последнего уравнения будет значение $b=9$.

Таким образом, пара чисел $(8, 9)$ будет цифровой подписью сообщения $m=5$.

Если любой другой пользователь сети желает проверить цифровую подпись в сообщении, он должен получить из базы данных открытый ключ первого пользователя (он равен 2), вычислить два числа c_1 и c_2 и сравнить их.

$$c_1 = Y_1^a \times a^b \bmod P = 2^8 \times 8^9 \bmod 11 = 10, c_2 = A^m \bmod 11 = 10$$

Так как $c_1 = c_2$, то цифровая подпись первого пользователя в сообщении $m=5$ верная.

п.4. Модели основных криптоаналитических атак.

Так как наиболее востребованными задачами криптографии являются задачи обмена ключами и аутентификации, то для взлома этих протоколов разработаны специальные типы атак.

Атака методом сведения к середине применяется для нарушения обмена ключами. Она возможна, если злоумышленник имеет возможность перехватывать все сообщения в канале связи. Атака строится по следующей схеме:

1. Злоумышленник перехватывает сообщение с ключом первого участника и посылает вместо него свой открытый ключ.

2. Аналогично перехватывает сообщение с ключом второго участника и посылает первому участнику свой собственный открытый ключ.

3. В дальнейшем злоумышленник перехватывает все сообщения участников, расшифровывает их своим тайным ключом, а затем шифрует перехваченными открытыми ключами и отправляет адресатам.

Словарная атака применяется для взлома систем аутентификации. Злоумышленник может составить словарь примерно из 1 миллиона наиболее распространённых паролей (используя статистические данные и результаты психологических исследований). Затем применяет к ним хэш-функцию и получает набор хэшей, который сравнивает с украденным с сервера файлом с паролями. Совпадающие хэш-значения позволяют определить некоторые из паролей.

Кроме атак существуют специальные формальные методы анализа криптографических протоколов для выявления изъянов этих протоколов в минимально возможные сроки. Всего существует 4 основных подхода к анализу криптографических протоколов.

Первый подход использует верификационные методы, основанные на теории автоматов и теории исчисления предикатов первого порядка, т.е. любой криптографический протокол представляется как некий формальный логический автомат и проверяется его работа.

Второй подход заключается в использовании экспертных систем, позволяющих определить, возникают ли в ходе выполнения шагов протокола такие нежелательные события, как компрометация ключа или разглашение пароля.

Третий подход, это так называемая БАН-логика – набор простых логических правил, легко применимых на практике и позволяющих выявить отдельные изъяны криптографических протоколов.

Четвёртый подход заключается в составлении некоторой алгебраической системы и изучение всевозможных состояний, которых она может достигнуть. Так находятся нелегитимные состояния.

В целом формальный анализ криптографических протоколов пока является довольно новой и до конца не сформировавшейся областью криптологии, поэтому будут появляться новые подходы и модифицироваться уже существующие.

Тема 11. Программно-технические методы защиты.

п.1. Программно-аппаратные средства.

Под программно-техническими средствами понимается совокупность информационных систем и технологий, направленных на автоматизацию решения задач защиты информации.

К аппаратным средствам защиты информации относятся электронные и электронно-механические устройства, включаемые в состав технических

средств информационной системы. К основным аппаратным средствам защиты информации относятся:

- а. устройства для ввода идентифицирующей пользователя информации (магнитные и пластиковые карты, отпечатков пальцев и т.п.);
- б. устройства для шифрования информации;
- в. устройства для воспрепятствования несанкционированному включению рабочих станций и серверов (электронные замки и блокираторы).

Под программными средствами защиты информации понимают специальные программы, включаемые в состав программного обеспечения информационной системы исключительно для выполнения защитных функций. К основным программным средствам защиты информации относятся:

- а. программы идентификации и аутентификации пользователей;
- б. программы разграничения доступа пользователей к ресурсам;
- в. программы шифрования информации;
- г. программы защиты информационных ресурсов от несанкционированного изменения, использования и копирования.

К преимуществам программных средств защиты информации относят:

- а. простота тиражирования;
- б. гибкость, возможность настройки на различные условия применения;
- в. простота применения;
- г. практически неограниченные возможности изменения для учёта новых угроз безопасности.

К недостаткам программных средств защиты относят:

- а. снижение эффективности информационной системы за счёт потребления её ресурсов защитными программами;
- б. более низкая производительность по сравнению с аналогичными аппаратными средствами;
- в. так как в основном используются пристыковочные средства защиты, то у злоумышленника существует потенциальная возможность их обхода;
- г. возможность изменения злоумышленником программного кода программы защиты.

п.2. Понятие информационного сервиса безопасности. Виды сервисов безопасности.

Информационная система может быть представлена как совокупность информационных сервисов, обеспечивающих выполнение основных функциональных задач ИС.

К сервисам безопасности относятся:

1. Идентификация и аутентификация
2. Управление доступом
3. Протоколирование и аудит

4. Шифрование
5. Контроль целостности
6. Экранирование
7. Анализ защищенности
8. Обеспечение отказоустойчивости
9. Обеспечение безопасного восстановления

Идентификация и аутентификация.

Идентификация и аутентификация – основа программно-технических средств информационной безопасности. Идентификация позволяет субъекту указать свое имя в информационной системе, аутентификация является мерой подтверждения введенного идентификатора. Аутентификация бывает односторонней (клиент доказывает подлинность серверу) или двусторонней (взаимной).

Применяются следующие общие методы идентификации:

- а. по биометрическим показателям пользователя;
- б. с использованием вводимого пароля;
- в. с использованием системы "ключ-замок";
- г. смешанные системы или системы с разделённым ключом;
- д. методы "запрос-ответ" и "рукопожатие".

Использование пароля при идентификации субъекта с одной стороны обеспечивает простоту и удобству для человека, но с другой стороны обеспечивается слабая защита. Поэтому необходимы дополнительные меры по обеспечению надежности парольной защиты:

1. Наложение технических ограничений (длина пароля, алфавит пароля)
2. Управление сроком действия пароля, их периодическая смена
3. Ограничение доступа к файлу паролей
4. Ограничение числа неудачных попыток входа в систему
5. Обучение пользователей
6. Использование программных средств генерации паролей

Биометрические показатели пользователей и возможности их использования.

Для выполнения идентификации и аутентификации пользователей часто используются биометрические данные:

1. Отпечатки пальцев;
2. Сетчатка и роговица глаза;
3. Геометрия руки и лица;
4. Голос и распознавание речи;
5. Подпись и работа с клавиатурой.

Эффективность систем идентификации по биометрическим показателям является недостаточно высокой. Это связано с тем, что:

- а. базы данных с биометрическими показателями занимают много места;
- б. уменьшение информации приводит к нечёткому распознаванию пользователей и возможностью получения доступа злоумышленнику;

в. увеличение информации приводит со временем к ошибкам распознавания легитимных пользователей и отказу в доступе;

г. ключ (биометрический образ) хранится в базе постоянно, а любой постоянный ключ потенциально подвержен взлому.

Таким образом, высокая оценка эффективности биометрической идентификации является искусственно завышенной и носит рекламный характер.

Сервисы управления доступом.

Управление доступом позволяет контролировать те действия, которые субъекты имеют право выполнять над информационными объектами. Традиционная постановка задачи состоит в существовании совокупности субъектов S_i и набора объектов O_j . Задача логического управления состоит в том, чтобы для каждой пары (S_i, O_j) определить множество допустимых операций и контролировать выполнения установленного порядка. Отношение «субъекты-объекты» может быть представлено в виде матрицы, в строках которой перечислены субъекты, в столбцах – объекты доступа. Клетки на пересечении строк и столбцов задают условия и права доступа. Поскольку такая матрица часто оказывается разреженной используются списки прав доступа, т.е. фактически столбцы данной матрицы. Контроль прав доступа производится специальными компонентами программной среды – ядром операционной системы, сервисами безопасности, системой управления базами данных, программными модулями промежуточного слоя.

При разрешении доступа проводится анализ следующей информации:

1. Идентификатор субъекта – дискреционный (произвольный) доступ
2. Атрибуты субъекта (метка безопасности, группа пользователей) – мандатный (принудительный) доступ

Недостатки дискреционного (произвольного) доступа:

1. управления доступом требует управления многими объектами, что требует разделение функций управления между многими пользователями.
2. права доступа существуют отдельно от данных, позволяет злоумышленнику, имеющему доступ к информации записать в доступный всем файл или подменить информацию.

Протоколирование и аудит.

Протоколирование – сбор и накопление информации о событиях ИС (внешних, внутренних, клиентских).

Аудит – анализ накопленной информации, проводимый оперативно или периодически.

Протоколирование и аудит позволяют решить следующие задачи:

- 1 Обеспечение подотчетности пользователей и администраторов ИС
- 2 Обеспечение реконструкции последовательности событий
- 3 Обнаружение попыток нарушений ИБ
- 4 Предоставление информации для выявления и анализа проблем

События, рекомендуемые для протоколирования:

- 1 Вход в систему
- 2 Выход из системы
- 3 Обращение к удаленной системе
- 4 Операции с файлами
- 5 Смена привилегий или иных атрибутов безопасности

При протоколировании рекомендуют записывать следующую информацию:

- 1 Дата и время события
- 2 Уникальный идентификатор субъекта – инициатора события
- 3 Результат события
- 4 Источник запроса
- 5 Имена объектов
- 6 Описание изменений, внесенных в базу данных защиты

Журнал аудита. Активный аудит.

Задача активного аудита – выявление подозрительной активности и управление средствами автоматического реагирования на нее. Активность, противоречащую политике безопасности, разделяют на атаки, направленные на незаконное получение полномочий и действия, выполняемые в рамках полномочий, но нарушающие политику безопасности (злоупотребление полномочиями).

Различают ошибки активного аудита первого и второго рода:

- а. Ошибки первого рода – пропуск атак
- б. Ошибки второго рода – ложные срабатывания

Модели активного аудита:

- а. Сигнатурный – на основе определения сигнатуры атаки (совокупность условий при которых считается, что атака имеет место) – велики ошибки первого рода (неумение обнаруживать неизвестные атаки).
- б. Статистический – на основе анализа выполняемых действий субъектов – велики ошибки второго рода.

Для разрешения задач реакции на события используется двухуровневая модель аудита:

Аудит первого уровня осуществляется на уровне авторизации пользователя и сервисом управления доступом. При этом фиксируются все действия, связанные как с правомерными, так и с неправомерными попытками доступа к ресурсам. В журнале аудита фиксируются все неправомерные, т.е. противоречащие установленной политике безопасности, действия, которые предотвращены механизмами защиты. Таким образом на первом уровне происходит непрерывная регистрация событий и накапливаются большие объёмы информации. Администратор безопасности имеет возможность анализировать эту информацию в любое время.

Аудит второго уровня осуществляется уровнем контроля корректности и контроля целостности, т.е. уровнем монитора безопасности. На этом уровне фиксируются в журнале аудита только критичные факты несанкционированного доступа, когда злоумышленник преодолевает

механизмы защиты. Таким образом, речь идет не о случайных ошибках пользователя, а о сознательном нарушении политики безопасности. При этом все сообщения поступают на специальную программу – сервер ошибок, часть сервера безопасности. Обработка сообщений производится либо в автоматическом режиме, либо при непосредственном участии администратора безопасности, но всегда в режиме реального времени.

п.3. Основы защиты корпоративных информационно-экономических систем.

С точки зрения информационной безопасности наиболее существенными являются следующие аспекты:

- 1 Корпоративная сеть является распределенной, связи между отдельными частями обеспечиваются внешними провайдерами
- 2 Корпоративная сеть имеет одно или несколько подключений к Internet
- 3 Критически важные серверы могут располагаться на различных площадках
- 4 Для доступа пользователей используются как компьютеры так и другие мобильные устройства
- 5 В течение одного сеанса работы пользователь обращается к нескольким информационным сервисам
- 6 Требования доступности информационных сервисов выдвигаются достаточно жесткие
- 7 Информационная система представляет собой сеть с активными агентами, в процессе работы программные модули передаются с сервера на компьютеры пользователя и т.п.
- 8 Не все пользовательские системы контролируются администраторами ИС
- 9 Программное обеспечение и модули полученные по сети не могут рассматриваться как надежные
- 10 Конфигурация ИС постоянно изменяется на уровнях администрирования данных, программ, аппаратуры

Потенциальные угрозы безопасности информации в ЛВС

1. Доступ в ЛВС со стороны штатного компьютера;
2. Доступ со стороны кабельных линий связи:
 - a) Со стороны штатного пользователя нарушителя;
 - b) При подключении постороннего компьютера и другой аппаратуры;
 - c) При побочных электромагнитных излучениях и наводках информации;
3. Аварийная ситуация, отказ аппаратуры, ошибки операторов и разработчиков программного обеспечения и т.п.

п.4. Основы защиты Internet-подключений.

При обмене информацией в сети соблюдаются следующие положения:

1. Каждый пользователь и процесс имеет свой уровень полномочий;

2. Проходящая транзитом через узел коммутации абонентская информация должна быть не видимой для персонала данного узла;
3. Транзитная абонентская информация не должна подвергаться документированию в узле;
4. Транзитная абонентская информация при обработке в узле не должна запоминаться в долговременной памяти.

Для решения вопросов информационной безопасности в сетях используются межсетевые экраны. В межсетевом экране может быть реализовано несколько видов защиты. К их числу относятся: фильтрация сетевых пакетов; средства идентификации и аутентификации пользователей; средства оповещения и сигнализации о выявленных нарушениях и т.д.

Фильтрация входящей и исходящей информации осуществляется на основе правил в нескольких уровнях.

На основе транспортных адресов отправителя и получателя производится фильтрация соединений на сетевом и транспортном уровне. Одновременно осуществляется контроль доступа в соответствии с установленными правилами разграничения доступа к сетевым ресурсам и сервисам.

Второй этап фильтрации выполняется на уровне приложений. Для этого создаются специальные фильтры прикладного уровня, каждый из которых отвечает за фильтрацию информационного обмена по одному отдельному протоколу и между одним определенным типом приложений. На этом уровне обрабатываются протоколы HTTP, FTP, SMTP, TELNET и SNMP.

С целью увеличения пропускной способности межсетевого экрана (а он рассчитан на работу в высокоскоростных сетях пропускной способностью до 100 Мб) могут быть созданы шлюзы приложений на уровне ядра операционной системы. Их основная задача - пропустить протокол, который они обслуживают, через межсетевой экран на уровне пакетного фильтра, что позволяет существенно повысить быстродействие межсетевого экрана. Через такие шлюзы пропускают данные для приложений, работающих по FTP, Rlogin/Rsh и RealAudio.

Тема 12. Защита данных и сервисов от воздействия вредоносных программ.

п.1. Вирусы. Виды вирусов.

Существует класс программ, которые были изначально написаны с целью уничтожения данных на чужом компьютере, похищения чужой информации, несанкционированного использования чужих ресурсов и т. п., или же приобрели такие свойства вследствие каких-либо причин. Такие программы несут вредоносную нагрузку и соответственно называются вредоносными.

К вредоносным программам относятся вирусы и программные закладки.

В ГОСТ Р 51272-99 «Защита информации. Объект информатизации. Факторы воздействующие на информацию. Общие положения» вводится следующее понятие вируса: Программный вирус – это исполняемый или интерпретируемый программный код, обладающий свойством несанкционированного распространения и самовоспроизведения в автоматизированных системах или телекоммуникационных сетях с целью изменить или уничтожить программное обеспечение и/или данные, хранящиеся в автоматизированных системах.

Программной закладкой называют программу, обладающую одной из разрушительных функций по отношению к информационной системе:

1. уничтожение или внесение изменений в функционирование программного обеспечения;
2. превышение полномочий пользователя с целью несанкционированного копирования конфиденциальной информации – "троянские программы";
3. подмена отдельных функций подсистемы защиты или создание в ней люков-уязвимостей;
4. перехват паролей пользователей (перехват всего клавиатурного ввода);
5. перехват потока информации, передаваемого в сети;
6. распространение в распределенных информационных системах, с целью реализации определенной угрозы – так называемые "черви" – самостоятельно действующие программы, не внедряющиеся в тела других файлов.

Компьютерные вирусы классифицируются по следующим признакам:

1. По способу распространения в информационной системе: файловые (заражающие файлы определенного типа), загрузочные (заражающие загрузочные сектора) и комбинированного типа;
2. По способу заражения: резидентные (часть кода которых постоянно находится в оперативной памяти) и нерезидентные (которые заражают только в момент непосредственного обращения к уже зараженным файлам);
3. По особенностям реализуемого алгоритма:
 - а. вирусы-спутники, создающие для заражаемых файлов одноименные файлы с кодом вируса и переименовывающие исходные файлы;
 - б. паразитические вирусы, которые обязательно изменяют содержимое заражаемых объектов;
 - в. "стелс"-вирусы, в которых путем перехвата обращений операционной системы к зараженным объектам и возврата вместо них оригинальных незараженных данных скрывается факт присутствия вируса;
 - г. вирусы-призраки (полиморфы), каждая следующая копия которых в зараженных объектах отличается от предыдущих.

п.2. Антивирусное программное обеспечение.

Антивирусные программы - это программы, основной задачей которых является защита именно от вирусов, или точнее, от вредоносных программ.

Обязательным средством антивирусной защиты является использование специальных программ для обнаружения и удаления вирусов в различных объектах информационной системы. Современное антивирусное программное обеспечение использует множество методик обнаружения вирусов и предотвращения заражения. Основными являются:

1. Сканирование – просмотр проверяемых объектов и поиск сигнатур (уникальных последовательностей байтов) известных вирусов. Соответствующие программные средства называют сканерами, а при наличии дополнительных средств обезвреживания вирусов – полифагами.
2. Обнаружение изменений в объектах информационной системы путем сравнения их вычисленных при проверке хеш-значений с эталонными. Программы, использующую эту методику, называются ревизорами или инспекто-

рами. потенциально подобные программы могут обнаружить и новые, ранее неизвестные вирусы.

3. Эвристический анализ – проверка объектов информационной системы с целью обнаружения фрагментов исполняемого кода, характерного для компьютерных вирусов. Потенциально эвристические анализаторы могут обнаружить новые разновидности вирусов.

4. Постоянное присутствие в оперативной памяти компьютера модуля антивирусной программы с целью обнаружения и пресечения попыток проникновения в компьютерную систему потенциально вредоносного программного обеспечения. Подобные программы получили название мониторы. Обычно мониторы используют общую со сканерами базу сигнатур и загружаются в оперативную память на этапе загрузки операционной системы.

5. Вакцинирование – присоединение к защищаемому файлу специального модуля контроля, следящего за целостностью данного файла с помощью вычисления хеш-значения и сравнения с эталоном. Подобная методика во многих случаях не применима, когда потенциально защищаемый файл будет многократно изменяться легитимными пользователями.

При выборе антивирусной программы необходимо учитывать не только процент обнаружения вирусов, но и способность обнаруживать новые вирусы, количество вирусов в антивирусной базе, частоту ее обновления, наличие дополнительных функций.

В настоящее время серьезный антивирус должен уметь распознавать не менее 25000 вирусов. Это не значит, что все они находятся "на воле". На самом деле большинство из них или уже прекратили свое существование или находятся в лабораториях и не распространяются. Реально можно встретить 200-300 вирусов, а опасность представляют только несколько десятков из них.

Существует множество антивирусных программ. Рассмотрим наиболее известные из них.

Norton AntiVirus 4.0 и 5.0 (производитель: «Symantec»).

Один из наиболее известных и популярных антивирусов. Процент распознавания вирусов очень высокий (близок к 100%). В программе используется механизм, который позволяет распознавать новые неизвестные вирусы.

В интерфейсе программы Norton AntiVirus имеется функция LiveUpdate, позволяющая щелчком на одной-единственной кнопке обновлять через Web как программу, так и набор сигнатур вирусов. Мастер по борьбе с вирусами выдает подробную информацию об обнаруженном вирусе, а также предоставляет вам возможность выбора: удалять вирус либо в автоматическом режиме, либо более осмотрительно, посредством пошаговой процедуры, которая позволяет увидеть каждое из выполняемых в процессе удаления действий.

Антивирусные базы обновляются очень часто (иногда обновления появляются несколько раз в неделю). Имеется резидентный монитор.

Недостатком данной программы является сложность настройки (хотя базовые настройки изменять, практически не требуется).

Dr Solomon's AntiVirus (производитель: «Dr Solomon's Software»).

Считается одним из самых лучших антивирусов (Евгений Касперский как-то сказал, что это единственный конкурент его AVP). Обнаруживает практически 100% известных и новых вирусов. Большое количество функций, ска-

нер, монитор, эвристика и все что необходимо чтобы успешно противостоять вирусам.

McAfee VirusScan (производитель: «McAfee Associates»).

Это один из наиболее известных антивирусных пакетов. Очень хорошо удаляет вирусы, но у VirusScan хуже, чем у других пакетов, обстоят дела с обнаружением новых разновидностей файловых вирусов. Он легко и быстро устанавливается с использованием настроек по умолчанию, но его можно настроить и по собственному усмотрению. Вы можете сканировать все файлы или только программные, распространять или не распространять процедуру сканирования на сжатые файлы. Имеет много функций для работы с сетью Интернет.

.Dr.Web (производитель: «Диалог Наука»)

Популярный отечественный антивирус. Хорошо распознает вирусы, но в его базе их гораздо меньше чем у других антивирусных программ.

Antiviral Toolkit Pro (производитель: «Лаборатория Касперского»).

Это антивирус признан во всем мире как один из самых надежных. Несмотря на простоту в использовании он обладает всем необходимым арсеналом для борьбы с вирусами. Эвристический механизм, избыточное сканирование, сканирование архивов и упакованных файлов - это далеко не полный перечень его возможностей.

Лаборатория Касперского внимательно следит за появлением новых вирусов и своевременно выпускает обновления антивирусных баз. Имеется резидентный монитор для контроля за исполняемыми файлами.

3. Защита системы электронной почты. Спам.

Слово "SPAM" на компьютерном жаргоне означает различные рекламные рассылки, распространяющиеся в автоматическом режиме. На самом деле, спам – это такие консервы, расшифровывается это слово как SPiced hAM – перченая ветчина.

Начав с конференций UseNet в 1998 году, спаммеры переключились на электронную почту. Составляя списки из миллионов адресов, спаммеры рассылают коммерческую рекламу сомнительных продуктов, сайтов и полулегальных услуг. В последнее время составлены программы-роботы для рассылки спама. Купив такую программу, желающие могут разослать по 100 и более миллионам адресов предложение купить у них какой-нибудь товар. Спам практически ничего не стоит для отправителя. Согласно исследованиям GYU, только 9,2% пользователей читают спам-сообщения. При этом данная цифра сформирована благодаря пользователям-новичкам, а из тех, кто провел в сети более 3 лет, спам читают лишь 5,4 %. 12% пользователей сети пишут возмущенные письма по обратному адресу, а 1,5 % пользователей производят вендетту (это могут быть "почтовые бомбы" в адрес злоумышленника, жалоба провайдеру и т.д.).

Спамерным атакам подвергаются не только корпоративные пользователи сети, но и владельцы домашних РС, имеющих выход в Internet. Этот факт существенно осложняет борьбу со спамом и вовлекает в неё не только самих пользователей, но и широкую общественность. SPAM составляет до 90% полного объема почтовых сообщений. Рассылка SPAM стала достаточно доходной частью полукриминального бизнеса.

На сегодняшний день спам признан одной из основных угроз в Интернете. В марте 2003 года Америка Он-Лайн (AOL) блокировала один миллиард спам-сообщений в день. Данные компании по фильтрации спама показывают, что общий объем спама удваивается каждые пять месяцев. Эти данные основаны на мониторинге одного миллиарда сообщений электронной почты в месяц.

Угрозы, вызванные спамом, можно разделить на три категории: угрозы для граждан, угрозы для организаций и угрозы глобальной инфраструктуре.

Угроза для граждан и организаций, прежде всего, состоит в том, что большая часть спам-сообщений часто заражена вирусами, червями или троянскими конями. Также услуги и товары, предлагаемые спам-рассылками, в большинстве своём являются недоброкачественными. На их фильтрацию уходит время, обращение хотя бы к одной рассылке вызывает лавинообразное увеличение рассылок, так как адрес электронной почты попадает в списки рассылок. Многочисленные рассылки могут перегрузить почтовый адрес, что приведет к отказу в доставке действительно важных писем.

Угроза глобальной инфраструктуре связана с тем, что борьба со спамом – дорогостоящее мероприятие. Возрастающие объемы спама вызывают повышение услуг, оказываемых Интернет-провайдерами: им приходится повышать пропускную способность каналов, увеличивать количество и ёмкость носителей для хранения больших объемов информации. К тому же возрастает объем технической поддержки, необходимой для обработки огромных объемов ненужных почтовых сообщений.

Спам-технологии становятся тем более изощренными, чем более сложными становятся средства борьбы с ними. Запретительные и организационные меры противодействия наиболее эффективны на уровне пользователей, технологические решения – на корпоративном уровне, а законодательные – на глобальном, международном уровне.

В последнее время появилось достаточное число коммерческих и общедоступных программ фильтрации SPAM. Эффективность современных фильтров SPAM достигает 90%. Примерами технологических решений являются проверка на соответствие RFC 2821, проверка контента, составление и проверка, так называемых, "чёрных" и "белых" списков. Так, RFC 2821 забракует сообщение электронной почты в следующих случаях:

- IP-адрес источника не соответствует имени устройства отправителя;
- обратный адрес не определяется;
- имя хоста сервера, с которого пришло сообщение, не является полным квалифицированным доменным именем.

Тема 13. Стандарты обеспечения информационной безопасности.

п.1. Критерии безопасности компьютерных систем министерства обороны США ("Оранжевая книга").

Оценочные стандарты направлены на классификацию информационных систем и средств защиты по требованиям безопасности. Первым оценочным стандартом, получившим широкое распространение, стал стандарт Министерство обороны США «Критерии оценки доверенных компьютерных систем»

(«Оранжевая книга») – 1983 г. В данном стандарте рассматриваются вопросы управления доступа к данным (т.е. обеспечение конфиденциальности и целостности информации). Степень доверия оценивается по двум критериям:

- Политика безопасности – набор правил, определяющих как обрабатывается, защищается и распространяется информация;
- Уровень гарантированности – меры доверия, которая может быть оказана архитектуре и реализации ИС.

«Оранжевая книга» предусматривает 4 группы критериев, соответствующие различной степени защищенности: от минимальной (группа D) до формально доказанной (группа A). Каждая группа содержит по одному или несколько классов. Уровень защищенности возрастает от группы D к группе A, а внутри группы с увеличением класса:

- Группа D. Минимальная защита.
- Группа C. Дискреционная защита.
- Группа B. Мандатное управление доступом.
- Группа A. Верифицированная защита.

В «Оранжевой книге» определены три категории требований безопасности: политика безопасности, аудит (подотчетность), корректность (гарантии). В рамках этих категорий введены шесть требований: четыре из них направлены на обеспечение безопасности непосредственно, две – на оценку качества средств защиты.

Политика безопасности

- Требование 1. Система должна поддерживать точно определенную политику безопасности. Возможность доступа субъектов к объектам определяется на основе их идентификаторов и набора правил управления доступом.
- Требование 2. С объектами должны быть ассоциированы метки безопасности, используемые в качестве исходной информации для процедур контроля доступа. Система должна обеспечивать возможность присвоения каждому объекту метку, определяющую степень конфиденциальности и режимы доступа к объекту.

Подотчетность

- Требование 3. Все объекты должны иметь универсальные идентификаторы. Контроль доступа осуществляется на основе идентификации субъектов и объектов и правил разграничения. Средства идентификации и аутентификации должны быть защищены от несанкционированных действий.
- Требование 4. Для определения ответственности пользователей, все происходящие в системе события, имеющие значение для безопасности, должны отслеживаться и регистрироваться в защищенном протоколе.

Гарантии (корректность)

- Требование 5. Средства защиты должны содержать независимые аппаратные или программные компоненты, обеспечивающие работоспособность функций защиты. Основной принцип контроля корректности состоит в том, что средства контроля независимы от средств защиты.
- Требование 6. Все средства должны быть защищены от несанкционированного вмешательства или отключения. Данное свойство долж-

но соблюдаться в любом режиме функционирования системы защиты и компьютерной системы в целом.

п.2. Руководящие документы Гостехкомиссии России.

Показатели защищенности средств вычислительной техники (СВТ) от несанкционированного доступа (НСД):

- В руководящих документах ГТК устанавливается классификация СВТ по уровню защищенности от НСД. Показатели защищенности содержат требования защищенности СВТ от НСД к информации. Конкретные перечни показателей определяют классы защищенности и описываются совокупностью требований.

- Установлено семь классов защищенности СВТ от НСД. Самый низкий класс – седьмой, самый высокий – первый.

Классы защищенности автоматизированных систем:

- Установлено девять классов защищенности автоматизированных систем от НСД, распределенных по трем группам. Каждый класс отвечает совокупностью требований к средствам защиты. В пределах группы соблюдается иерархия классов защищенности АС.

- Третья группа включает автоматизированные системы, в которых работает один пользователь, допущенный ко всей информации автоматизированной системы. В группе два класса – 3Б и 3А.

- Вторая группа включает автоматизированные системы, в которых пользователи имеют одинаковые полномочия доступа ко всей информации, обрабатываемой и хранимой в автоматизированной системе на носителях разного уровня конфиденциальности. В группе два класса – 2Б и 2А.

- Первая группа включает многопользовательские автоматизированные системы, где одновременно обрабатывается и хранится информация разных уровней конфиденциальности. Различные пользователи имеют различные права. В группе пять классов – 1Д, 1Г, 1В, 1Б, 1А.

При выполнении классификации рассматриваются подсистемы защиты и требования к ним:

- Подсистема управления доступом
- Подсистема регистрации и учета
- Криптографическая подсистема
- Подсистема обеспечения целостности

п.3. Международные стандарты информационной безопасности.

Стандарт ISO/IEC 15408 "Критерии оценки безопасности информационных технологий" является международным оценочным стандартом в области информационной безопасности. Выпущен в 1999 г. Часто для его обозначения используется наименование "Общие критерии". "Общие критерии" являются метастандартом, определяющим инструменты для оценки безопасности информационных систем и порядок их использования. В отличие от "Оранжевой книги" и других подобных стандартов, "Общие критерии" не содержат предопределенных классов

безопасности. Данные классы могут быть построены для конкретной организации или информационной системы.

В данном стандарте введены два основных вида требований безопасности:

- Функциональные требования, соответствующие активному аспекту защиты и предъявляемые к функциям безопасности и реализующим их механизмам.

- Требования доверия, соответствующие пассивному аспекту защиты, предъявляемые к технологии и процессу разработки и эксплуатации ИС.

Требования безопасности предъявляются для определенного программно-аппаратного продукта, а их выполнение проверяется с целью оценки уровня информационной безопасности. Общие критерии рассматривают объект оценки в контексте некоторой среды безопасности, характеризующейся определенными условиями и угрозами.

Для характеристики угрозы информационной безопасности используются следующие параметры:

- Источник угрозы;
- Метод воздействия на объект оценки;
- Уязвимости, которые могут быть использованы;
- Ресурсы, которые могут пострадать от реализации.

Одним из основных нормативных документов, определяемых в Общих критериях, является профиль защиты. Профиль защиты – документ, включающий в себя типовой набор требований, которым должны удовлетворять системы определенного класса. Задание по безопасности (проект защиты) – содержит совокупность требований к конкретной разработке, выполнение которых обеспечивает достижение поставленных целей. Функциональные требования сгруппированы в Общих критериях на основе выполнения определенной роли. Всего в Общих критериях определено 11 функциональных классов, 66 семейств и 135 компонентов.

Классы функциональных требований:

- Идентификация и аутентификация;
- Защита данных пользователя;
- Защита функций безопасности (относится к целостности и контролю сервисов и механизмов безопасности);
- Управление безопасностью (требования к управлению атрибутами и параметрами безопасности);
- Аудит безопасности;
- Доступ к объекту оценки;
- Приватность (защита пользователя от раскрытия и использования его идентификационных данных);
- Использование ресурсов (требование доступности информации);
- Криптографическая поддержка;
- Связь (аутентификация сторон при обмене данными);
- Доверенный маршрут/канал (для связи с сервисами безопасности).

Установление доверия безопасности основывается на исследовании объекта оценки. Всего определено 10 классов, 44 семейства и 93 компонента требований доверия. Классы требований доверия безопасности:

- Требования к разработке системы (поэтапная детализация функций безопасности);
- Поддержка жизненного цикла (требование к модели жизненного цикла);
- Тестирование;
- Оценка уязвимостей (включая оценку стойкости функций безопасности);
- Поставка и эксплуатация;
- Управление конфигурацией;
- Руководства (требования к эксплуатационной документации);
- Поддержка доверия;
- Оценка профиля защиты;
- Оценка задания на безопасность.

Тема 14. Основные технологии построения защищённых экономических информационных систем.

п.1. Общие принципы построения защищенных систем.

Структура подсистемы безопасности и её программно-техническое наполнение является коммерческой тайной корпорации, которая эксплуатирует данную систему. Но в открытом доступе можно найти информационные документы, описывающие методику разработки защищенных систем. Одним из таких документов является "Защищенные информационные системы. Информационный документ корпорации Microsoft", в котором сформулированы основные цели и задачи модели защищенных информационных систем. Можно выделить три общих качества, которые, по мнению большинства людей, должны присутствовать в любой защищенной технологии: безопасность, безотказность и деловая добросовестность (т. е., добросовестность организации, предоставляющей технологию). Существует множество разнообразных концепций защищенности, каждая из них охватывает только узкую область. Например, есть концепции доверия в операциях электронной коммерции и взаимного доверия между системами удостоверения личности, и есть анализы восприятия компьютеров в обществе; однако подлинно эффективный подход должен объединять различные аспекты: и с инженерной точки зрения, и с точки зрения политики в этой области и пользователей.

Поскольку защищенность – понятие сложное, полезно проанализировать задачу создания защищенных информационных систем с нескольких различных точек зрения. При формальном подходе к разработке рассматривают три уровня, на которых описывают различные точки зрения на проблему защищенности: цели, средства и исполнение (реализация).

Цели описывают защищенность с точки зрения конечного пользователя. Основную цель можно рассматривать в следующей формулировке: "Основания для пользователя считать систему защищенной". Исходя из этой цели, качества защищенной информационной системы можно сформулировать следующим образом:

Безопасность. Информация и операции пользователя остаются конфиденциальными и находятся в безопасности. Личная информация не оказывается раскрытой без разрешения. Вирусы не заражают персональный компьютер и информационную систему в целом и не приводят его в негодность. Взломщик не может привести систему в нерабочее состояние или несанкционированным образом изменить содержащиеся в ней данные.

Безотказность. Пользователь может быть уверен, что продукт выполнит свои функции тогда, когда это потребуется. При установке новой программы, не нужно беспокоиться, будет ли она правильно работать с существующими приложениями. Имеется постоянный доступ к основным сервисам информационной системы, никогда не возникает сообщения "Система недоступна". Утилиты и вспомогательные сервисы работают исправно и не создают внештатных ситуаций.

Деловая добросовестность. Поставщик продукта проявляет ответственность и готовность помочь. Провайдер услуг или разработчик программного обеспечения получая сведения о проблеме, реагирует на неё быстро и эффективно.

п.2. Средства разработки и правила их реализации.

Средства — это принципы делового и инженерного характера, используемые, чтобы достичь целей. В то время как цели по большей части ориентированы на конечного пользователя, средства — это внутренние принципы в рамках компаний. Перечислим основные средства, применяемые при разработке защищенных информационных систем:

- Защищенность. Предприняты шаги для защиты конфиденциальности, целостности и готовности к работе данных и систем.

- Конфиденциальность. Данные о пользователе никогда не собираются и не передаются другим людям и организациям без его согласия. Конфиденциальность достигается в случае сбора, хранения и использования информации в соответствии с "Принципами честного использования информации" (Fair Information Practices).

- Готовность к работе. Система доступна и готова к использованию при необходимости

- Управляемость. Систему легко установить и ей легко управлять — с учетом ее размера и сложности. Масштабируемость, эффективность и экономичность рассматриваются как элементы управляемости. Масштабируемость — способность системы эффективно справляться с увеличением объемов данных и вычислительных мощностей в рамках существующей архитектуры и принципов работы.

- Точность. Система правильно выполняет свои функции. Результаты расчетов не содержат ошибок, и данные защищены от потери и повреждения.

- Удобство использования. С программным обеспечением легко работать, и оно отвечает потребностям пользователя.

- Готовность помочь. Компания берет на себя ответственность за проблемы и предпринимает меры по их устранению. Клиентам оказывается помощь в планировании приобретения продукта, его установке и

работе с ним.

- Прозрачность. Компания открыто ведет свои дела с клиентами. Ее побуждения ясны, она держит свое слово, и клиенты знают, какова их роль в операциях и взаимодействиях с компанией.

п.3. Фундаментальные проблемы, возникающие при построении защищенных информационных систем.

Проектирование, создание и внедрение защищенной информационной системы является сложно структурированной задачей, проблемы при решении которой возникают на каждом этапе. Эти проблемы имеют различный характер, обусловленный не только техническими вопросами, но и социально-экономическими. Перечислим основные из них:

1. Политические вопросы. Увеличение защищенности многих систем не в интересах государства и правительственных агентств крупных держав, особенно в контексте борьбы с терроризмом. Поэтому многие производители умышленно снижают защиту своих коммерческих систем, чтобы её могли обойти органы безопасности.

2. Сложность обработки данных. Увеличение информационных систем, проникновение их во все сферы жизни и охват большого количества конечных пользователей приводит к существенному усложнению вопроса, что, в свою очередь, осложняет обработку потоков данных. Таким образом, чем больше система, тем сложнее сделать её защищенной, так как необходимо учитывать все возможные легитимные ситуации и проводить обработку больших потоков данных.

3. Идентификация личности. При создании защищенных компьютерных систем возникает противоречие, заключающееся в том, что конечный пользователь опасается предоставлять полную информацию о себе, так как она может быть использована третьим лицом. А производитель системы или корпорация, её эксплуатирующая, стремится получить наиболее полную информацию о пользователе, с целью его однозначной идентификации. Хранение и защита идентифицирующей информации является одной из основных и сложных задач при создании защищенных информационных систем.

4. Человеческий фактор. Система с защитой любой сложности на многих своих этапах зависит от действий людей, например, системных администраторов. Поэтому необходимо учитывать влияние человеческого фактора и, по возможности, сводит его влияние к минимуму.

5. Средства программирования. Несмотря на то, что в последнее время сам процесс программирования существенно автоматизирован, появились мощные инструменты по устранению ошибок, тем не менее очень часто уязвимость той или иной системы обуславливается наличием в системе программных ошибок. Повышение уровня программистской подготовки специалиста с одной стороны, и создание интеллектуальных сред программирования с другой должно способствовать решению этой проблемы.

6. Совместимость систем. В современном мире существуют хорошо защищенные системы, например, диспетчерские транспортные системы. Но защищенность достигается за счет узкой специализации, закрытости и

ограниченной распространённости таких систем. Создание открытых защищенных систем, имеющих широкое распространение, ставит перед разработчиками технологические и концептуальные задачи совершенно другого уровня.

Информационное обеспечение дисциплины

1. Бабаш, А.В. Информационная безопасность. Лабораторный практикум: Учебное пособие / А.В. Бабаш, Е.К. Баранова, Ю.Н. Мельников. — М.: КноРус, 2013. — 136 с.
2. Гафнер, В.В. Информационная безопасность: Учебное пособие / В.В. Гафнер. — Рн/Д: Феникс, 2010. — 324 с.
3. Громов, Ю.Ю. Информационная безопасность и защита информации: Учебное пособие / Ю.Ю. Громов, В.О. Драчев, О.Г. Иванова. — Ст. Оскол: ТНТ, 2010. — 384 с.
4. Ефимова, Л.Л. Информационная безопасность детей. Российский и зарубежный опыт: Монография / Л.Л. Ефимова, С.А. Кочерга... — М.: ЮНИТИ-ДАНА, 2013. — 239 с.
5. Ефимова, Л.Л. Информационная безопасность детей. Российский и зарубежный опыт. Монография. Гриф УМЦ «Профессиональный учебник». Гриф НИИ образования и науки. / Л.Л. Ефимова, С.А. Кочерга. — М.: ЮНИТИ, 2013. — 239 с.
6. Запечников, С.В. Информационная безопасность открытых систем. В 2-х т. Т.1 — Угрозы, уязвимости, атаки и подходы к защите / С.В. Запечников, Н.Г. Милославская. — М.: ГЛТ, 2006. — 536 с.
7. Запечников, С.В. Информационная безопасность открытых систем. В 2-х т. Т.2 — Средства защиты в сетях / С.В. Запечников, Н.Г. Милославская, А.И. Толстой, Д.В. Ушаков. — М.: ГЛТ, 2008. — 558 с.
8. Малюк, А.А. Информационная безопасность: концептуальные и методологические основы защиты информации / А.А. Малюк. — М.: ГЛТ, 2004. — 280 с.
9. Партыка, Т.Л. Информационная безопасность: Учебное пособие / Т.Л. Партыка, И.И. Попов. — М.: Форум, 2012. — 432 с.
10. Петров, С.В. Информационная безопасность: Учебное пособие / С.В. Петров, И.П. Слинькова, В.В. Гафнер. — М.: АРТА, 2012. — 296 с.
11. Семененко, В.А. Информационная безопасность: Учебное пособие / В.А. Семененко. — М.: МГИУ, 2010. — 277 с.
12. Чипига, А.Ф. Информационная безопасность автоматизированных систем / А.Ф. Чипига. — М.: Гелиос АРВ, 2010. — 336 с.
13. Шаньгин, В.Ф. Информационная безопасность компьютерных систем и сетей: Учебное пособие / В.Ф. Шаньгин. — М.: ИД ФОРУМ, НИЦ ИНФРА-М, 2013. — 416 с.
14. Шаньгин, В.Ф. Информационная безопасность и защита информации / В.Ф. Шаньгин. — М.: ДМК, 2014. — 702 с.